Déploiement de clés de sécurité Yubikey pour l'authentification

I - Introduction :

A) Objectif du document :

Ce document est un guide d'administration détaillant les différentes étapes d'enrôlement d'un utilisateur dans le cadre du projet Passwordless. L'objectif principal de ce guide est de faciliter la mise en œuvre de l'exploitation des YubiKey par les utilisateurs. Il fournit aux administrateurs les ressources nécessaires pour une gestion efficace des YubiKey.

B) Public cible :

Ce guide s'adresse spécifiquement aux techniciens du supports chargés de la maintenance de l'infrastructure informatique. En fournissant des instructions claires, des bonnes pratiques et des prérequis, ce document vise à les habiliter dans la gestion des YubiKey et leur suivi d'inventaire.

C) Glossaire :

1- Le Passwordless :

C'est un paradigme d'authentification qui élimine la nécessité d'utiliser des mots de passe traditionnels. Le principe est de remplacer les mots de passe par des méthodes d'authentification plus fiables et faciles d'utilisation pour les utilisateurs.

Cette technologie repose sur des méthodes d'authentification alternatives comme la biométrie, les clés de sécurité physiques ou encore l'utilisation de notifications push pour garantir aux utilisateurs un accès sécurisé à leurs comptes.

2- Yubikey Series 5 NFC :

Clé de sécurité matérielle fabriquée par Yubico. Elle fait partie de la série 5 des produits YubiKey et intègre la technologie NFC (Near Field Communication), offrant ainsi une authentification sécurisée et Multifactorielle pour diverses applications. Elle embarque plusieurs protocoles d'authentification comme PIV ou Fido2.

3 - Protocole PIV (Personal Identity Verification) :

Standard de sécurité spécifiant les exigences pour la vérification de l'identité personnelle et définit un ensemble de commandes pour la gestion des clés, des certificats et des opérations cryptographiques sur des dispositifs de sécurité tels que les cartes à puce ou les YubiKey.

4 - Protocole Fido2 (Fast Identity Online 2) :

Ensemble de spécifications de l'Alliance FIDO (Fast Identity Online) visant à améliorer l'authentification en ligne. Il permet l'utilisation de méthodes d'authentification sans mot de passe, notamment les clés de sécurité, comme les YubiKey, pour renforcer la sécurité des accès en ligne de manière efficace et pratique.

5 - Windows Hello :

Windows Hello est une technologie d'authentification qui permet aux utilisateurs de se connecter à leurs appareils Windows à l'aide de données biométriques, ou d'un code confidentiel, au lieu d'un mot de passe traditionnel.

6 - Microsoft Authenticator :

Authenticator est une application développée par Microsoft, permettant de se connecter sans mots de passe à l'ensemble des services Microsoft (Office, Outlook, OneDrive, etc.)

Le fonctionnement de l'application est simple : au lieu de devoir entrer un mot de passe pour se connecter à un service Microsoft, une notification sera envoyée sur le téléphone. Il faudra juste valider la connexion avec son empreinte digitale, la reconnaissance faciale, ou un code PIN. Cette méthode à l'avantage d'offrir une meilleure sécurité, et peut aussi se montrer plus simple et rapide.

II – Le déploiement du Passwordless

A) Etapes préalables :

Voici la liste des étapes préalables à l'arrivée d'un utilisateur pour son enrôlement :

Etape 1 : *Convocation de l'utilisateur pour la configuration/remise de la clé (le format de la communication est à déterminer par le support)*

Etape 1 bis : *Détermination du modèle de clé pour l'utilisateur donné*

Etape 2 : *Pré-attribution de la clé pour un utilisateur donné sur le fichier de suivi*

Etape 2 bis : *Initialisation du code PUK s'il s'agit d'une clé provenant d'un réassort et pas du pool de base.*

Etape 3 : *Si l'utilisateur est :*

- Un nouvel arrivant
- Un intérimaire faisant du VDI

Dans ce cas, quand la demande de MFA va se faire, après la définition du mot de passe, à l'ouverture d'une application office 365 : Il faut le configurer sur SMS (téléphone tampon du support)

B) Déroulé de l'enrôlement passwordless :

Voici la liste des étapes à suivre lors de l'arrivée d'un utilisateur pour son enrôlement :

Etape 4 : Microsoft Auth

Le déploiement du passwordless se faisant conjointement avec la migration des téléphones mobiles dans Intune, le déploiement de la solution Microsoft Auth et sa configuration seront effectués en même temps que l'ajout dans Intunes des appareils mobiles.

Rappel de la marche à suivre dans le cas d'un utilisateur standard (utilisateur avec MFA & Google Auth sur son téléphone) :

- Arrivée de l'utilisateur
- Sauvegarde du Google Auth sur un téléphone tampon
- Enrôlement dans Intune du téléphone (Reset du téléphone via MobileIron -> Enrôlement du téléphone dans Intune -> Utilisation du Login/mdp + Google Auth pour l'enrôlement -> À la fin de l'enrôlement, installation automatique des applis sur le téléphone)
- Configuration du Microsoft Auth
- Test de connexion avec les applications Microsoft via le Microsoft Auth
- Ouverture du profil personnel de l'utilisateur via le Microsoft Auth (aka.ms/mysecurityinfo)
- Suppression de toutes les méthodes d'authentification autres que Microsoft Auth

Etape 4bis : Ajout dans les groupes passwordless

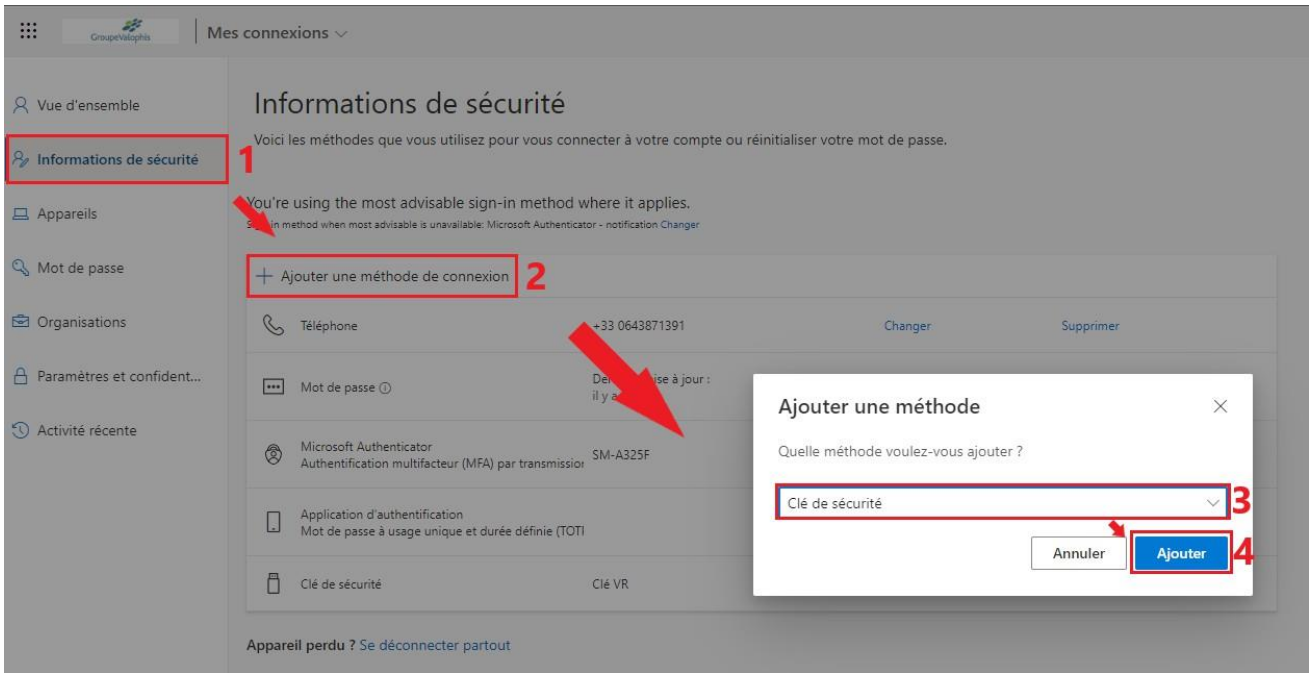
Avant de continuer la procédure de déploiement pour les yubikeys et le Windows Hello il faudra **impérativement** réaliser les actions suivantes :

- Ajouter le compte de l'utilisateur dans le groupe "**gp_Passwordless_Users**"
- Ajouter le poste de travail de l'utilisateur dans le groupe "**gp_Passwordless_Computers"**
- **Redémarrer** le poste de l'utilisateur
- Effectuer une **synchronisation** sur le serveur AdConnect (**action Infra**)

Pour les étapes suivantes il faudra prévoir un ordinateur portable tampon dans le cas où un utilisateur n'aurait pas de pc portable nominatif.

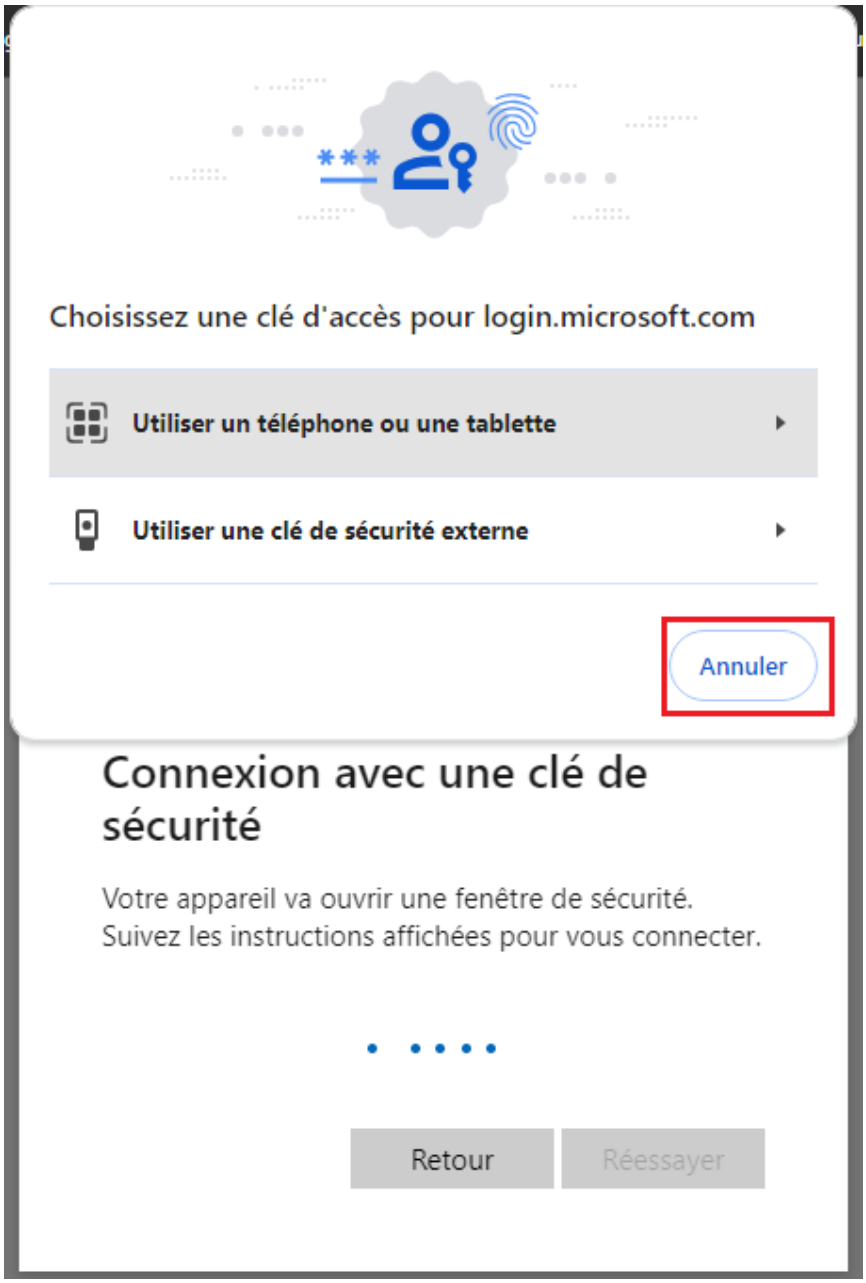
Etape 5 : Enrôlement FIDO2 de la Yubikey avec MFA

1- L'utilisateur doit se connecter à l'URL suivante en renseignant ses identifiants de son compte Microsoft : https://aka.ms/mysecurityinfo
2- Dans l'onglet « **Informations de sécurité** », l'utilisateur doit ajouter la méthode d'authentification « **Clé de sécurité** ».

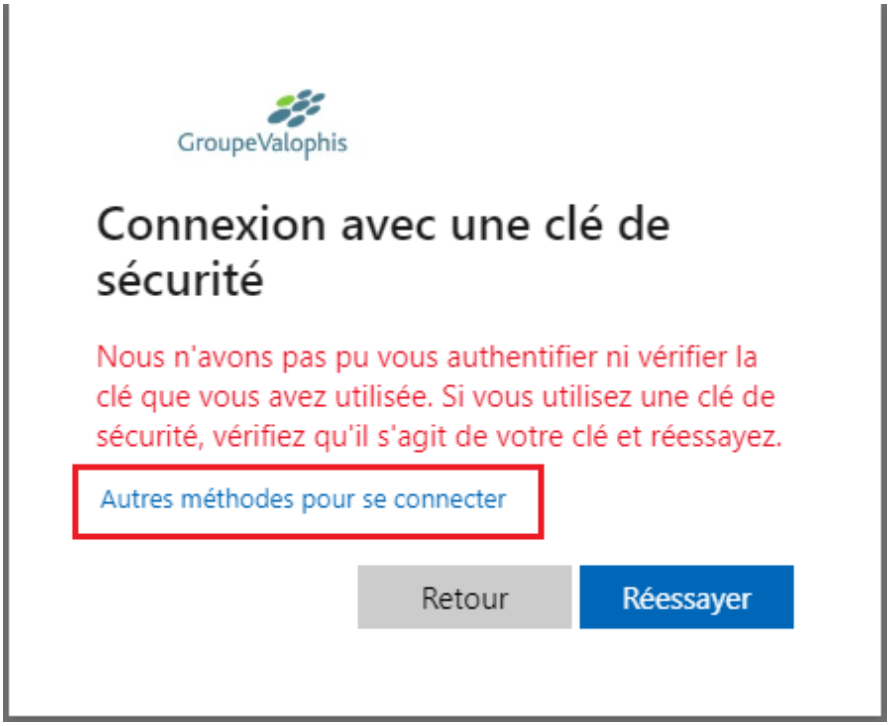


Attention ! En fonction de la situation de l'utilisateur enrôlé, le code MFA pourra vous être demandé, dans ce cas vous vous retrouverez directement au point n°7.

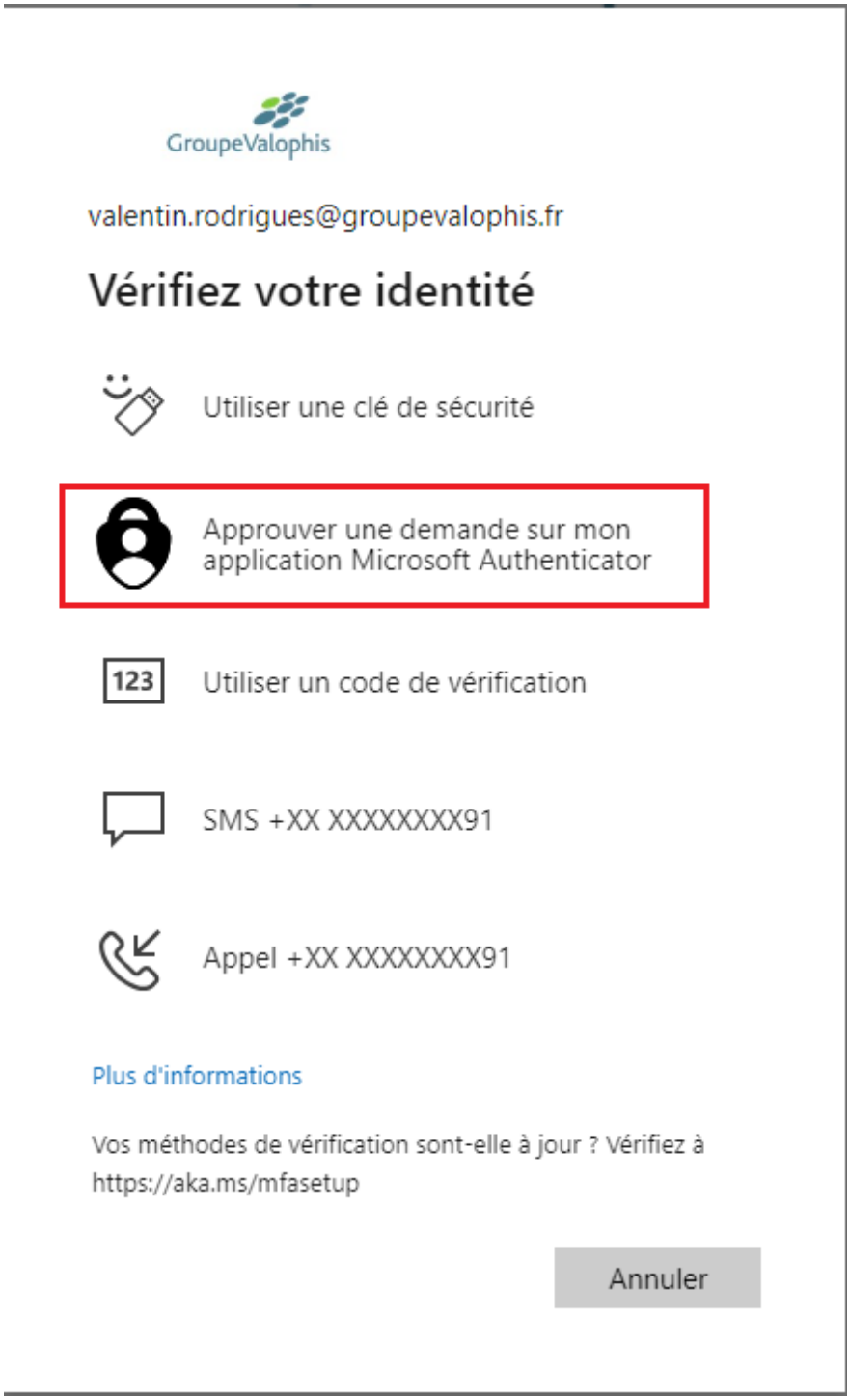
3- Dans la double boite de dialogue, cliquer sur « **Annuler** » dans la 1ère boite



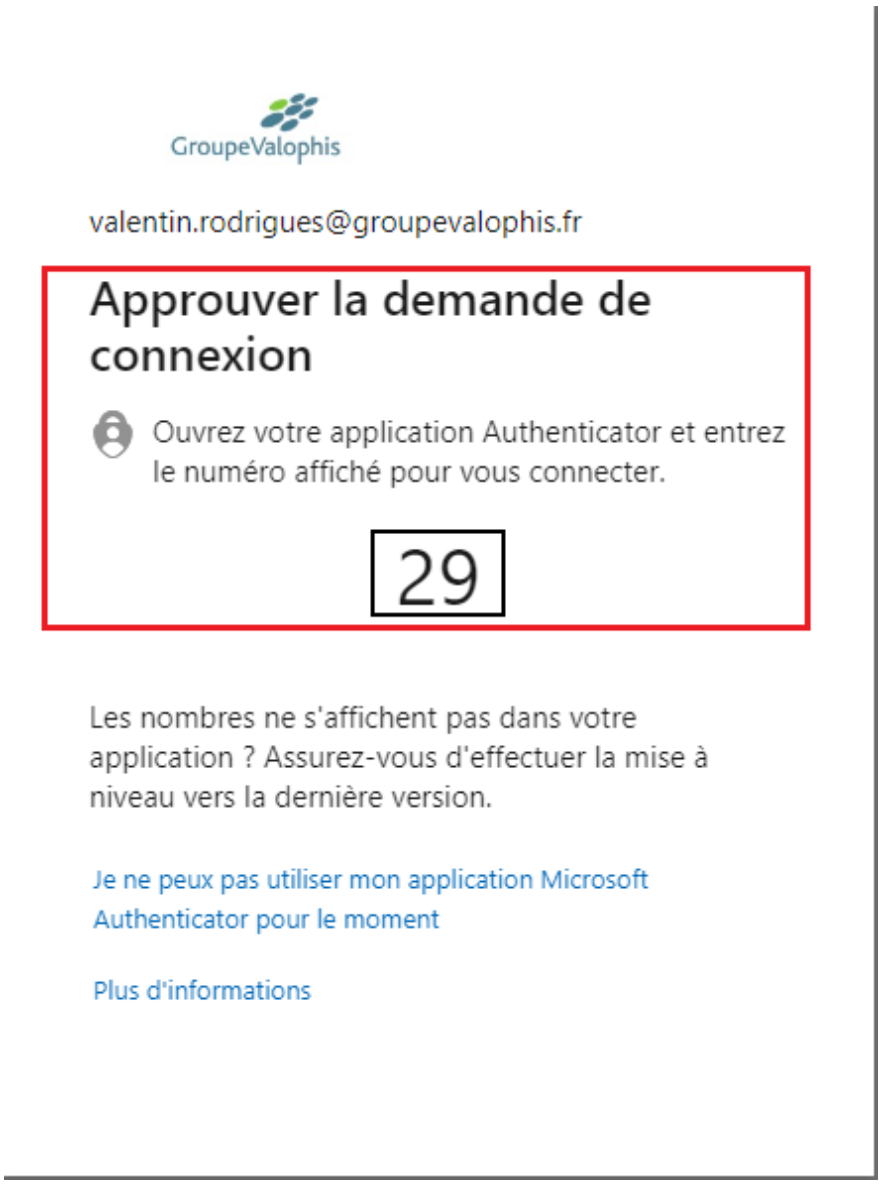
4- Puis cliquer sur « **Autres méthodes pour se connecter** »



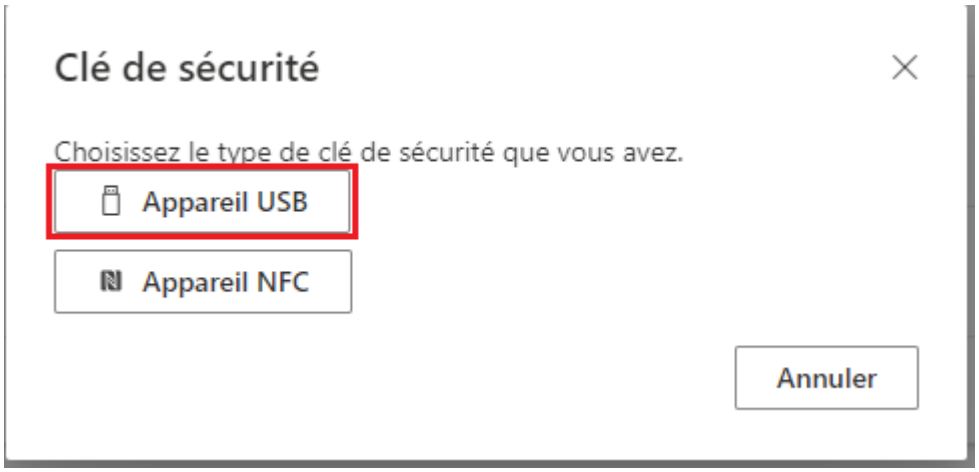
5- Puis il faut sélectionner la méthode d'authentification MFA dont dispose l'utilisateur : **Son Microsoft Auth**.



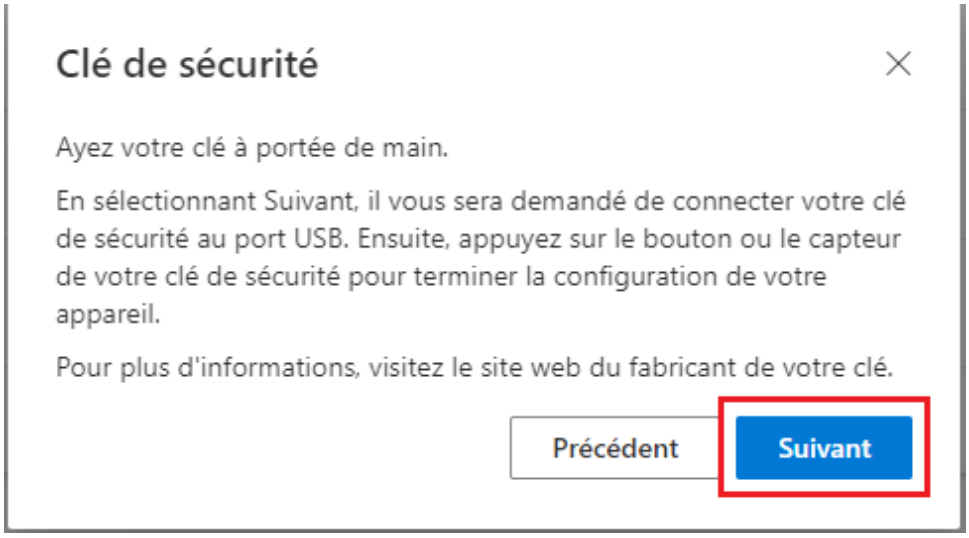
6- Il faudra ensuite **approuver la demande de connexion** en suivant les instructions affichées



7- Puis choisir « **Appareil USB** »

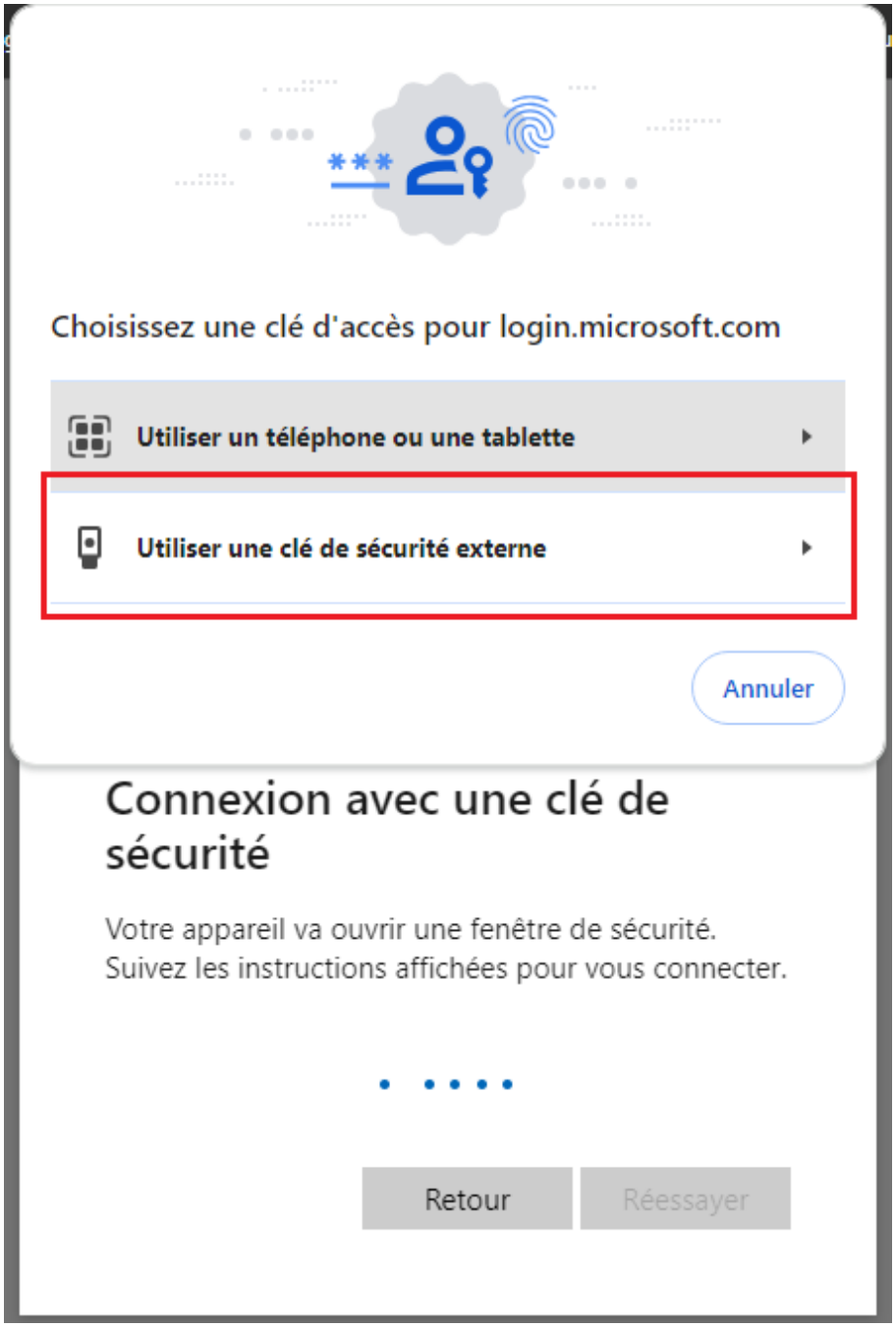


8- Cliquez sur « **Suivant** »

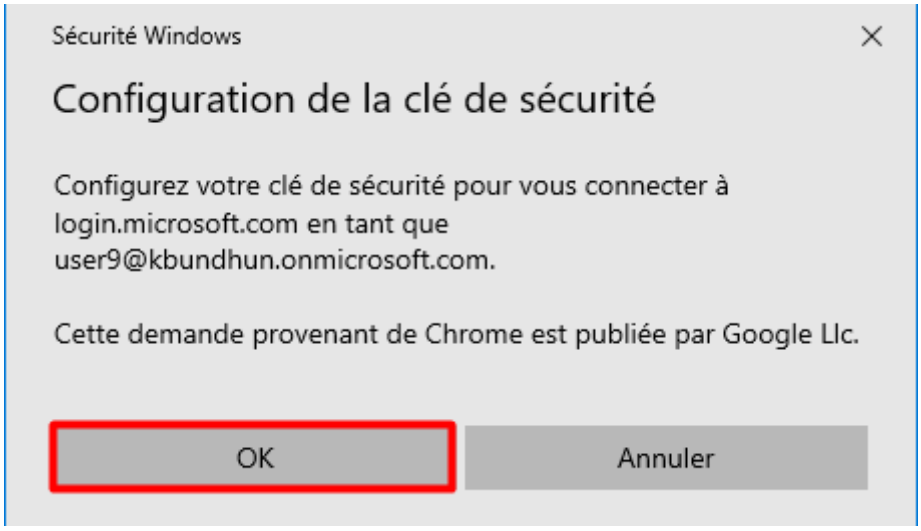


9- Dans la boite de dialogue qui apparait cliquez sur « **Enregistrer d'une autre façon** »

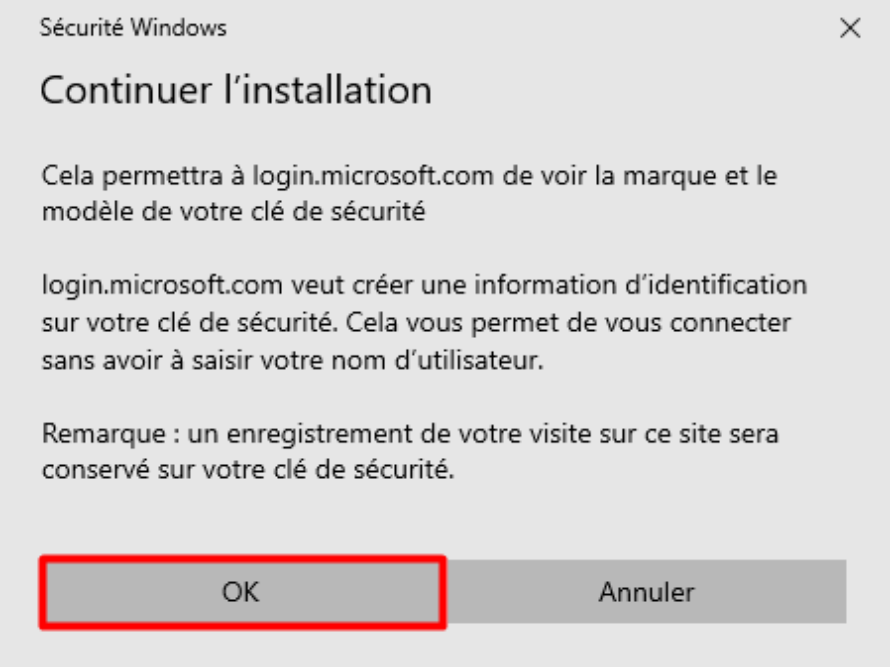
10- Dans la seconde boite de dialogue cliquez sur « **Utiliser une clé de sécurité externe** »



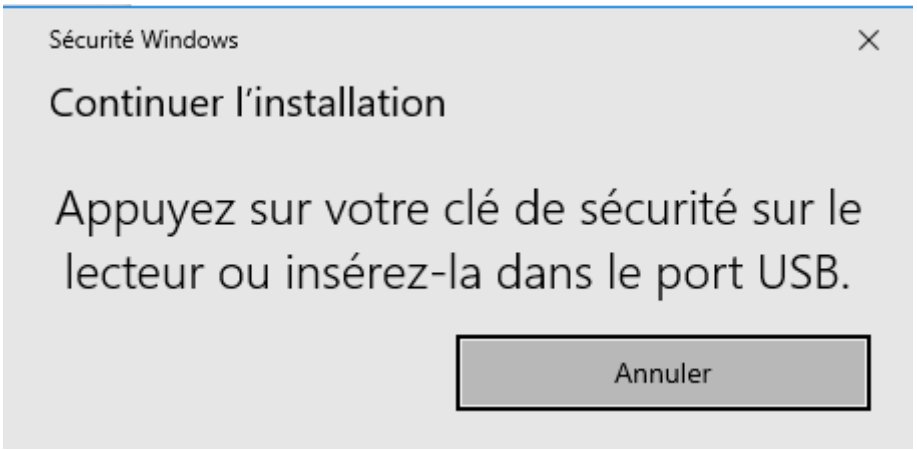
11- Cliquez sur « **OK** »



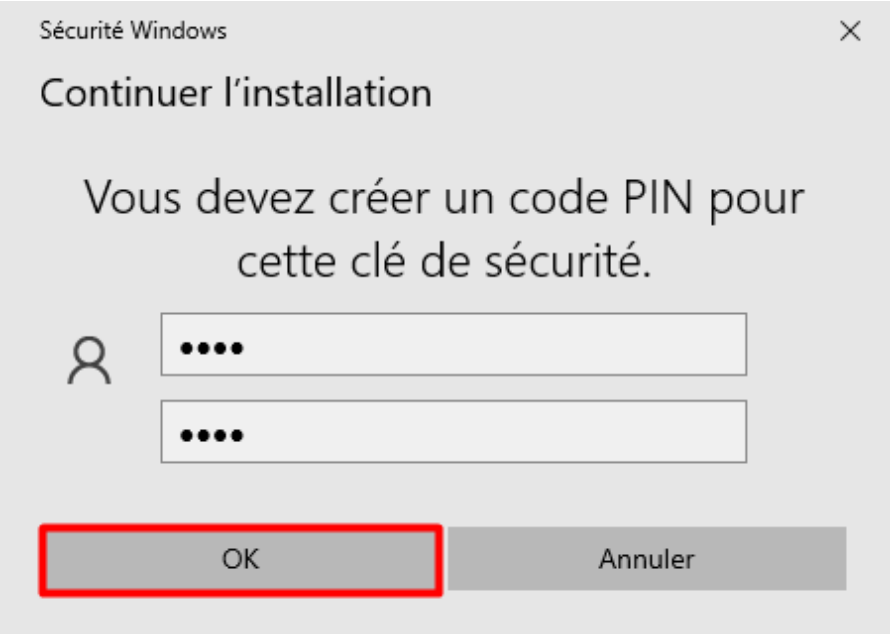
12- Cliquez sur « **OK** »



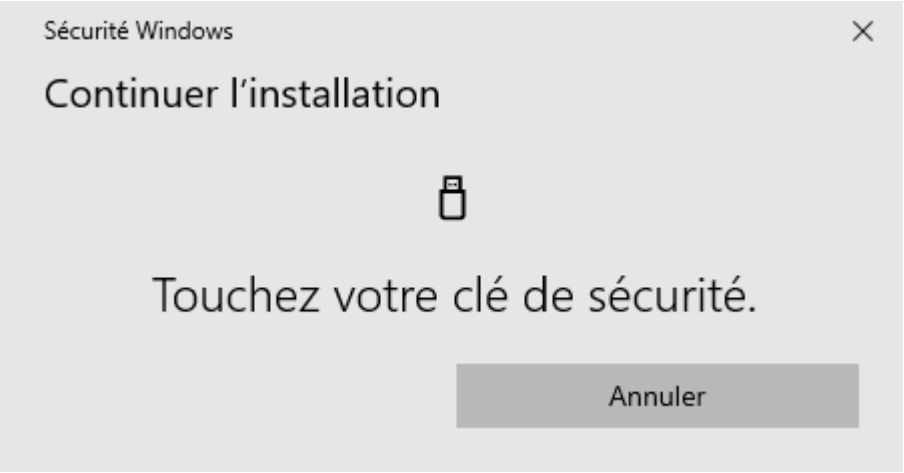
13- Insérez la **Yubikey**.



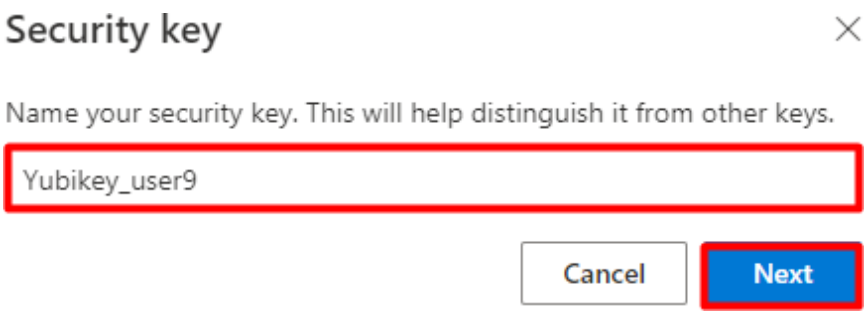
14- Définissez un code PIN pour le protocole Fido2 avec **minimum 6 caractères numériques**.



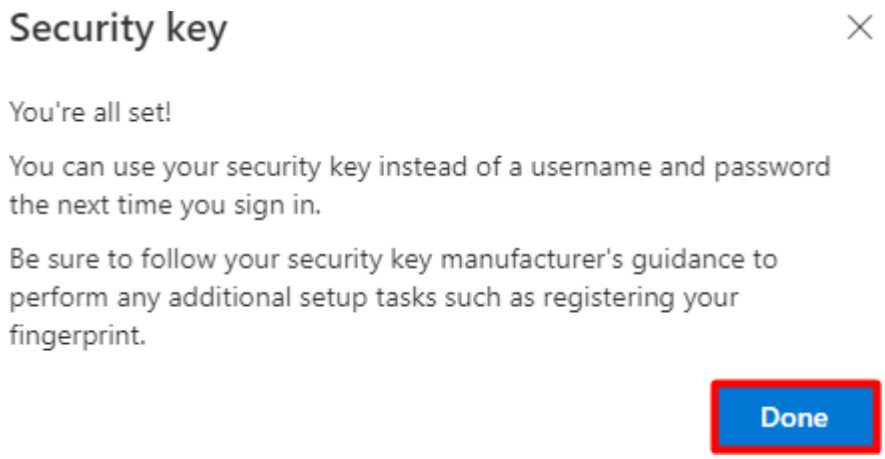
15- Touchez la Yubikey



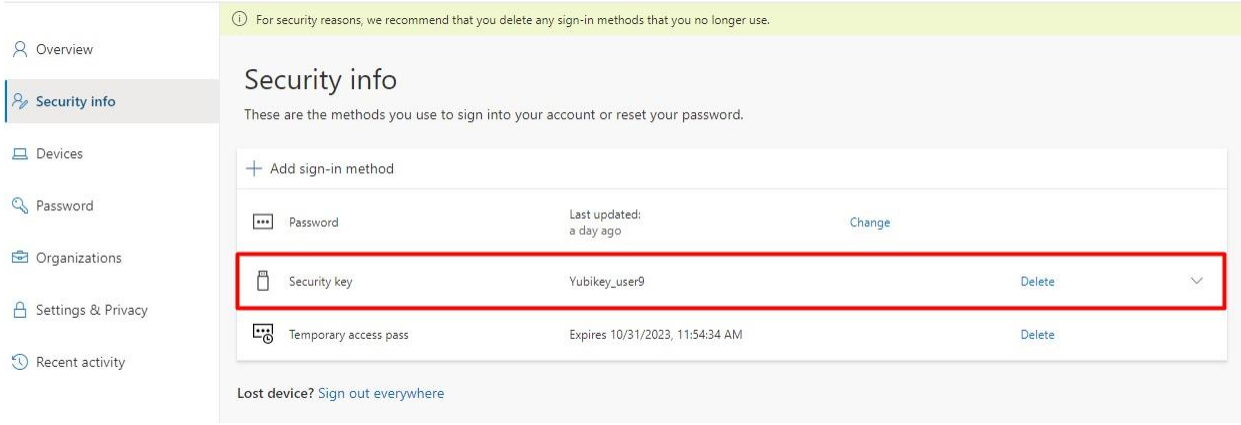
16- Ajoutez un nom au choix pour la Yubikey.



17- Cliquez sur « **Terminer** »



18- Vous devriez voir apparaître dans la page « **Informations de sécurité** » la nouvelle méthode d'authentification « **Clé de sécurité** » qui vient d'être configurée.



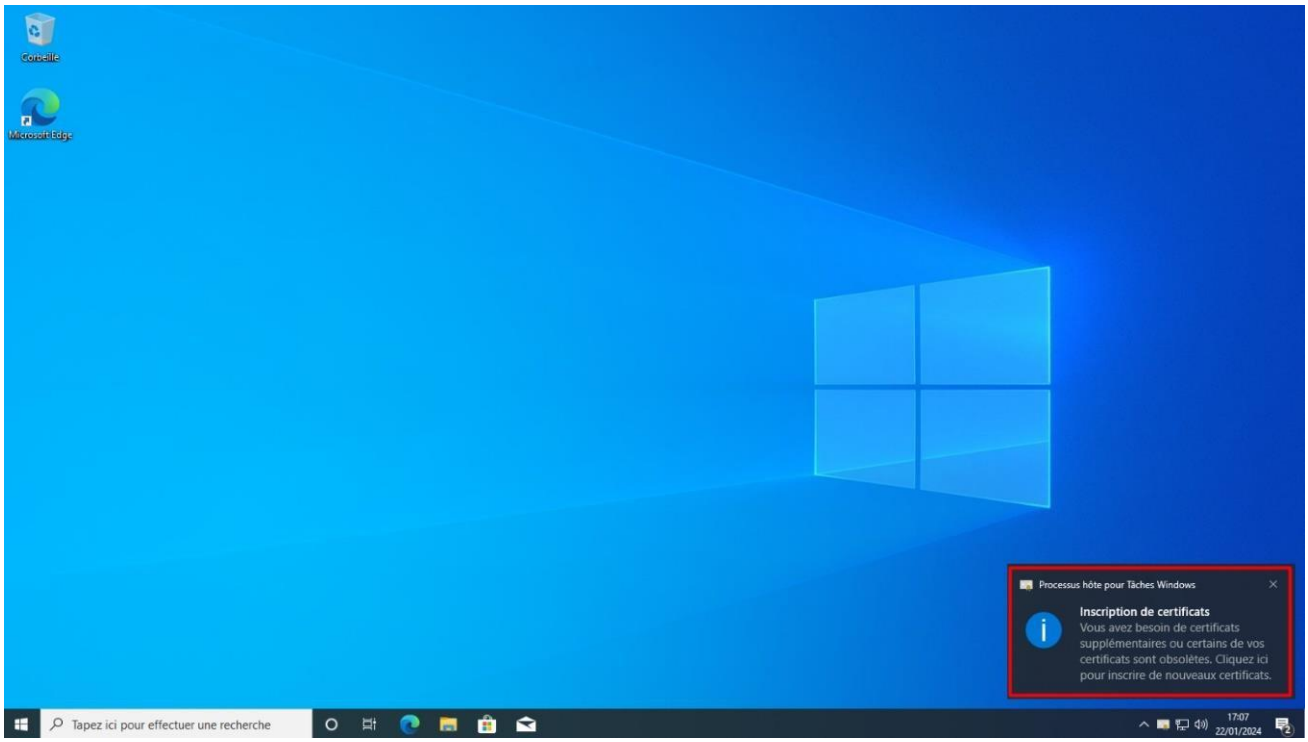
Etape 6 : Enrôlement par certificat de la Yubikey

Il existe 2 possibilités pour enrôler la méthode d'authentification par certificat (ou PIV) sur la Yubikey.

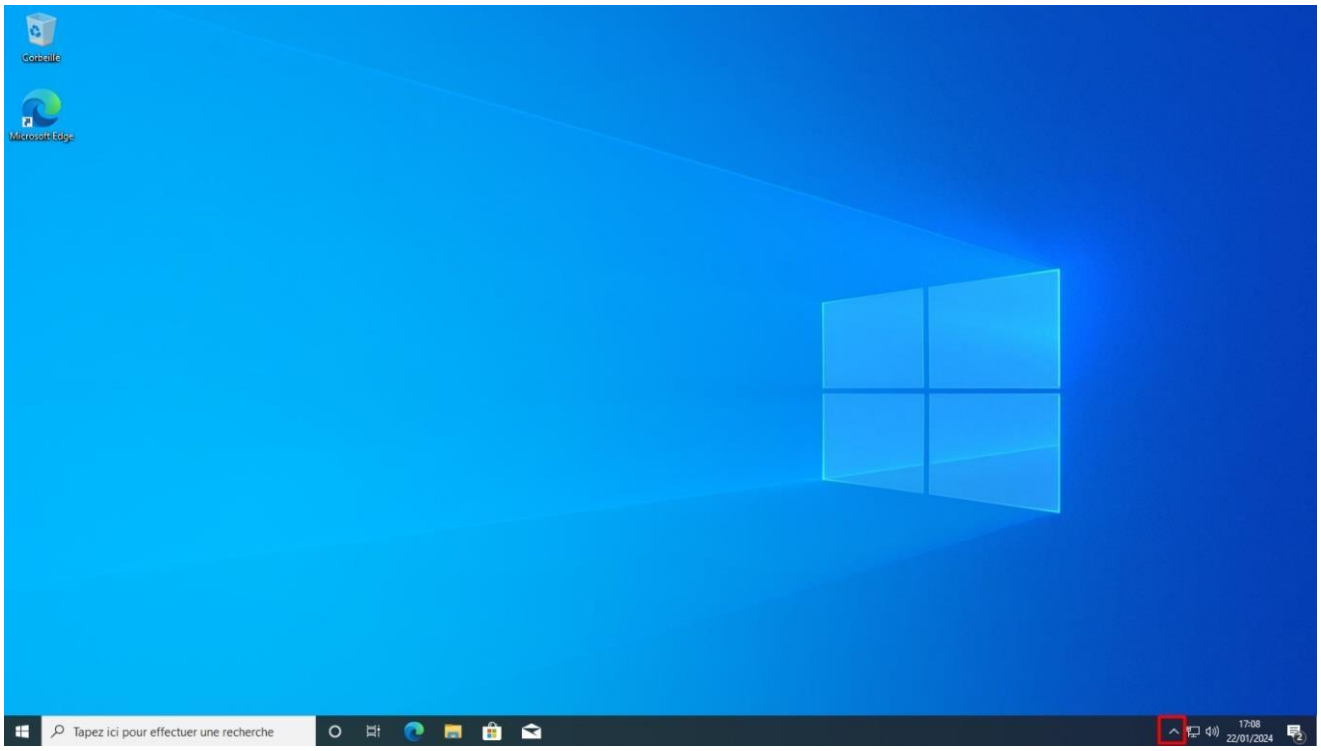
Méthode n°1 : Signature du certificat sur la Yubikey via le pop-up

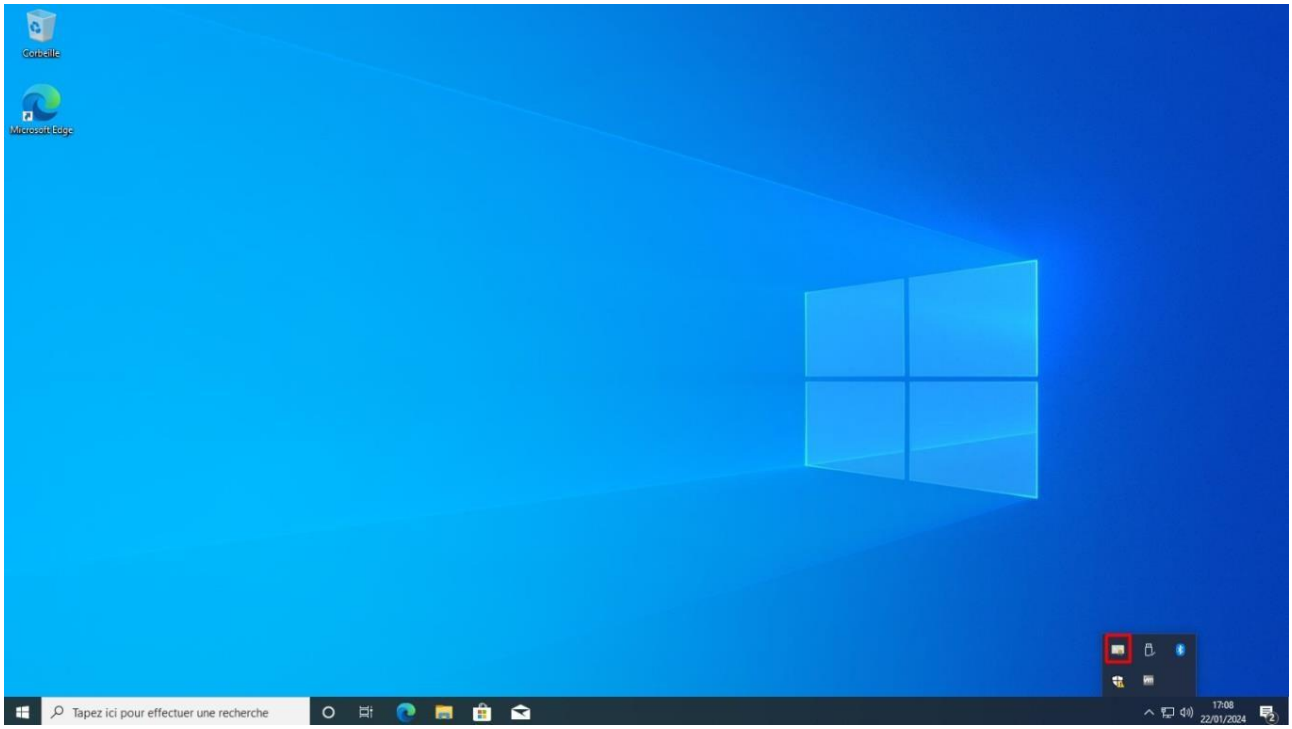
Après s'être connecté à la session, il faudra effectuer les actions suivantes :

1- À l'ouverture de session de l'utilisateur, un **popup d'inscription de certificats** apparaît.
Cliquez dessus pour commencer l'enrôlement.



2- Si le pop-up n'apparaît pas, vérifiez dans la barre des tâches en bas à droite et cliquez sur
l'icône de certificat.



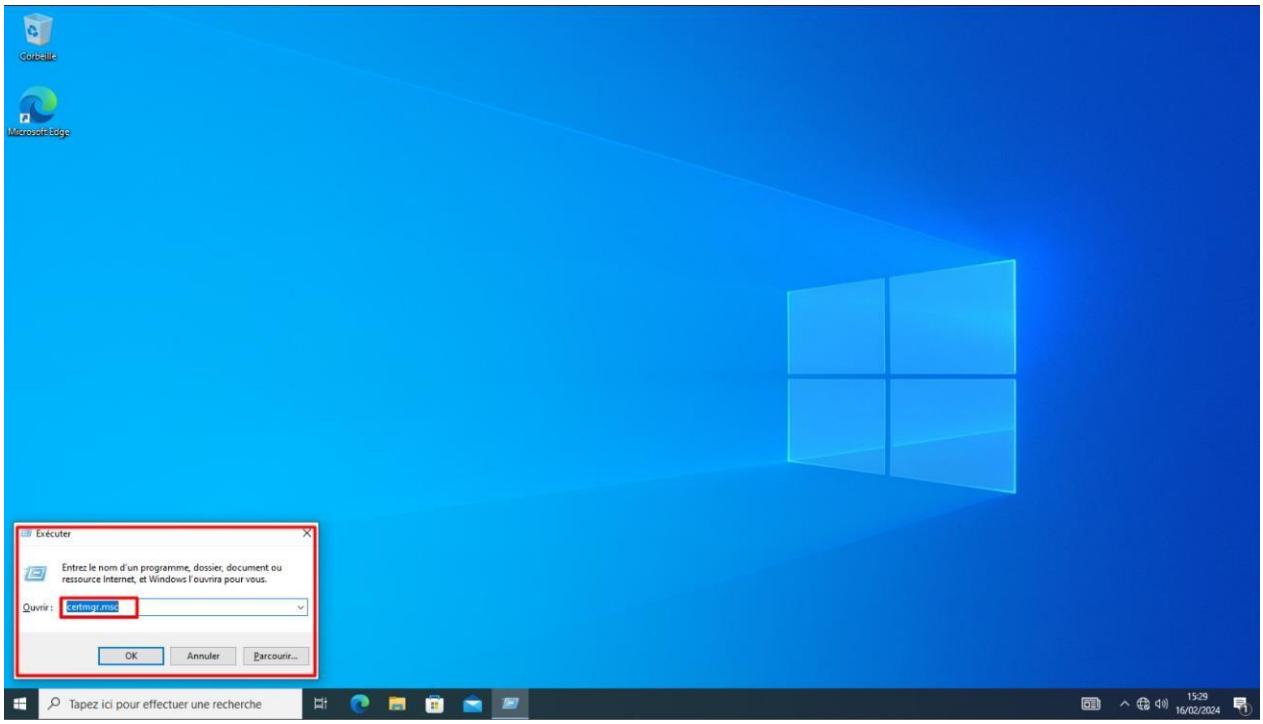


3- Si l'icône « **certificat** » n'apparaît pas, vous pouvez tenter de redémarrer le poste de travail.
En cas d'échec vous pouvez vous référer à la **méthode n°2**

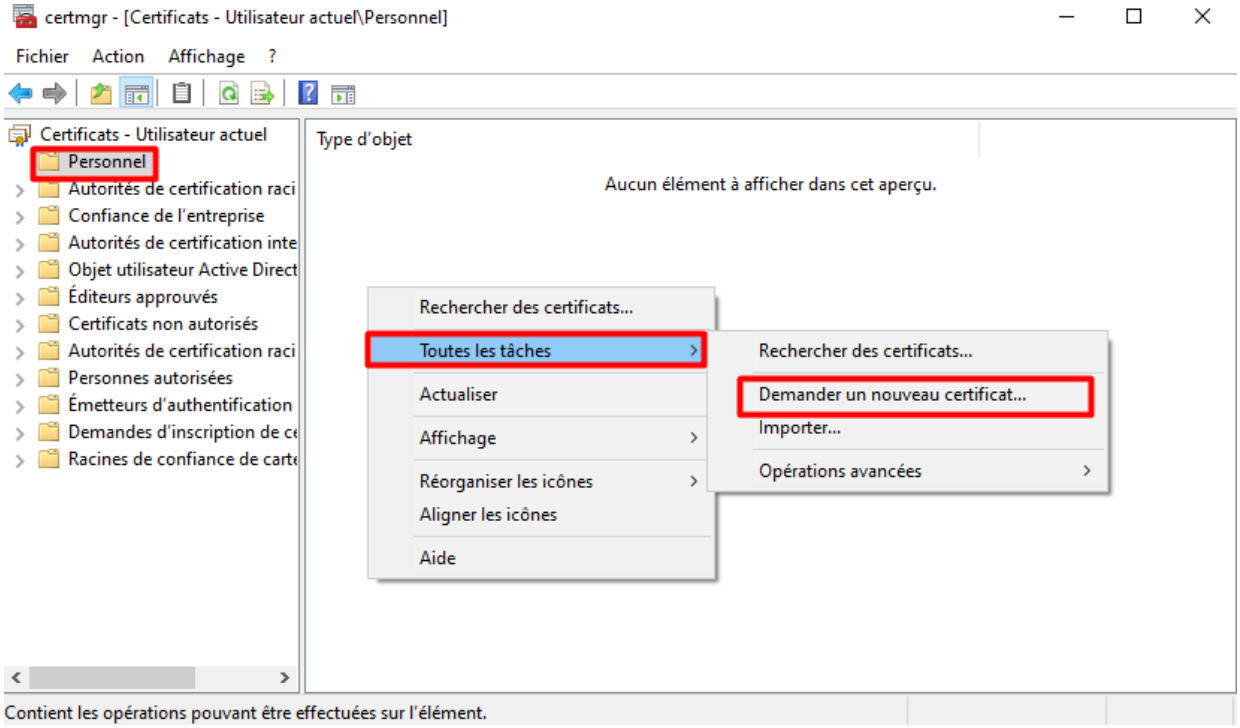
Méthode n°2 : Signature du certificat sur la Yubikey sans le pop-up

Si le pop-up précédemment présenté n'apparaît pas, il est tout de même possible de demander un certificat grâce à l'interface graphique. Pour cela effectuez les actions suivantes :

1- À la connexion sur la session Windows, il faudra appuyer sur la combinaison de touche « **Win + R** » et ouvrir le gestionnaire de certificats en exécutant « **certmgr.msc** ».

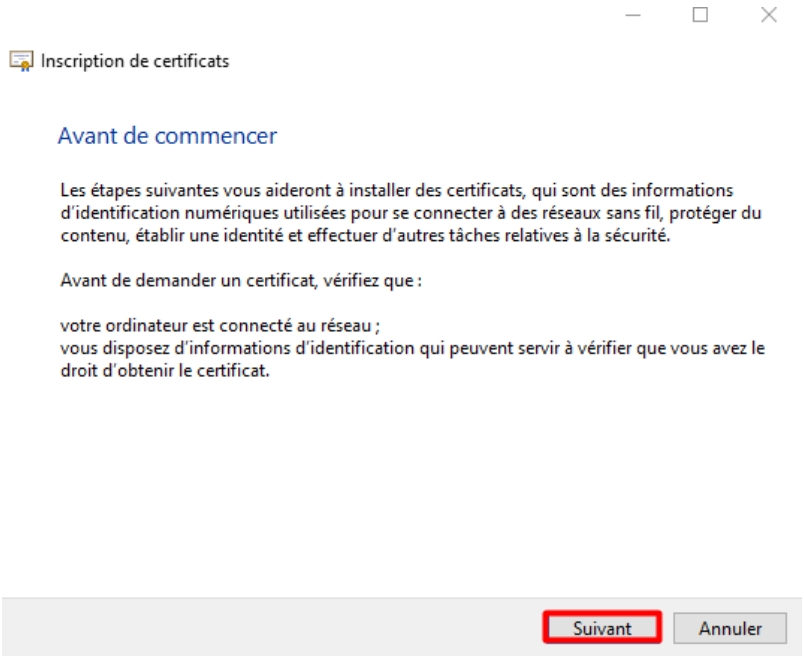


2- Sur la console, sous « ***Certificats – Utilisateur actuel*** », cliquez sur le dossier « ***Personnel*** ». Puis, dans la zone blanche, cliquez droit dessus et sélectionnez « ***Toutes les tâches > Demander un nouveau certificat…*** ».

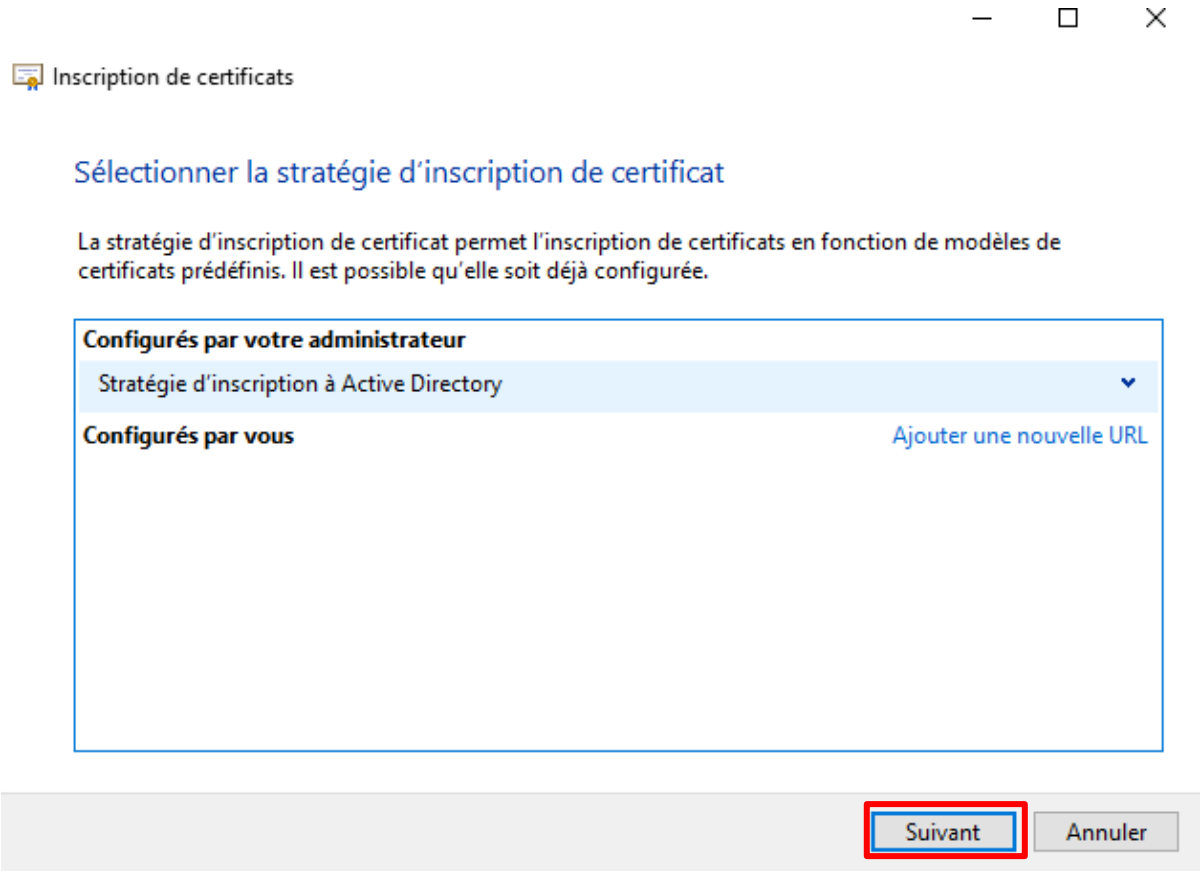


Suite de la procédure d'enrôlement par certificat :

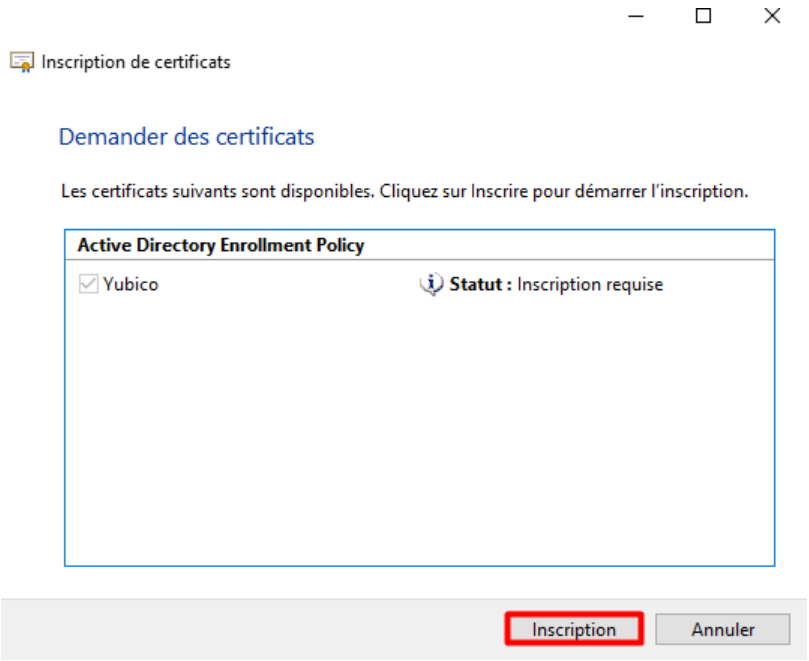
1- Après avoir suivi la méthode n°1 ou n°2, une fenêtre s'ouvrira, appuyez sur « **Suivant** »



2- Il vous sera ensuite demandé de sélectionner la stratégie d'inscription de certificat. Il suffira de cliquer sur « **Suivant** »

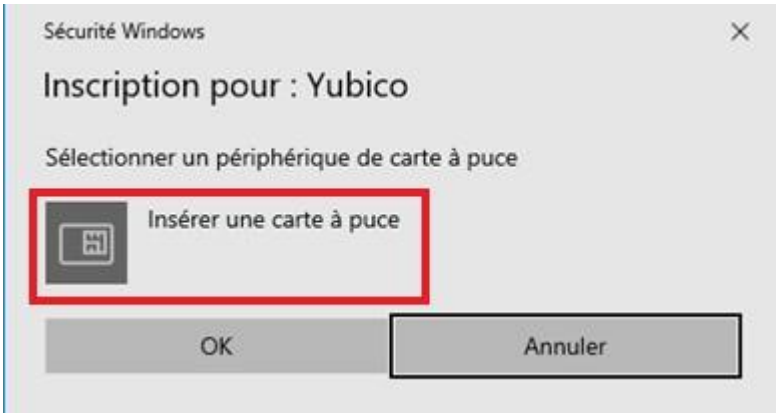


1- Puis il faudra s'assurer que la case « **Yubiko** » est bien cochée et cliquer sur



«**Inscription**»

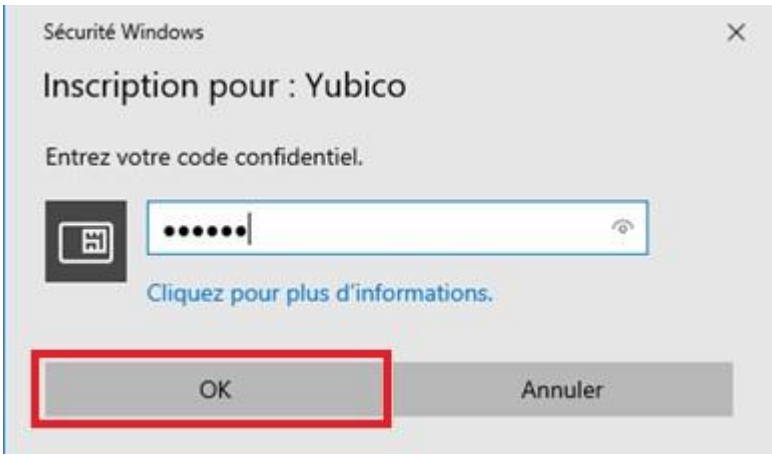
2- Il sera demandé d'insérer la Yubikey

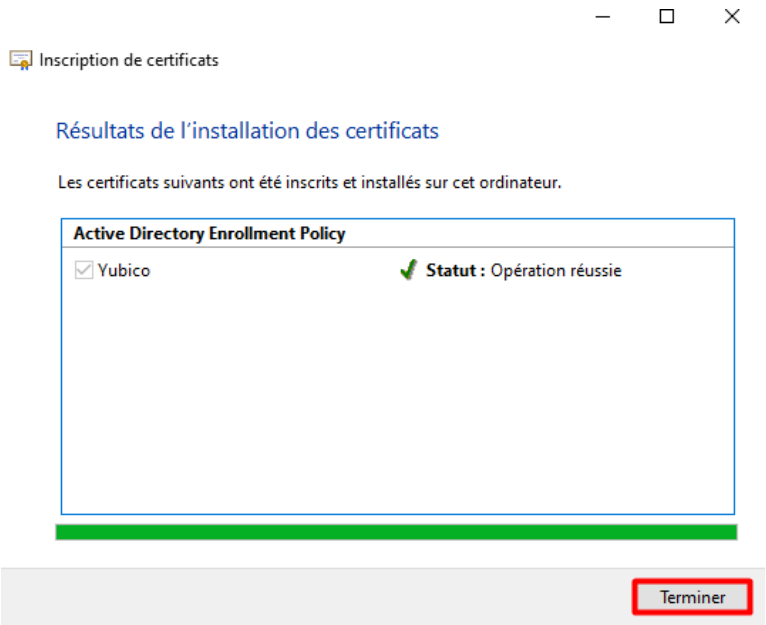


3- Une fois la clé insérée, vous devriez voir apparaître « **Yubikey Smart Card** » dans la boite de dialogue. Appuyez sur « **OK** »

4- Il vous sera alors demandé de renseigner le code PIN par défaut de la clé : « **123456** ». Un changement de code PIN sera réalisé dans les étapes

suivantes.



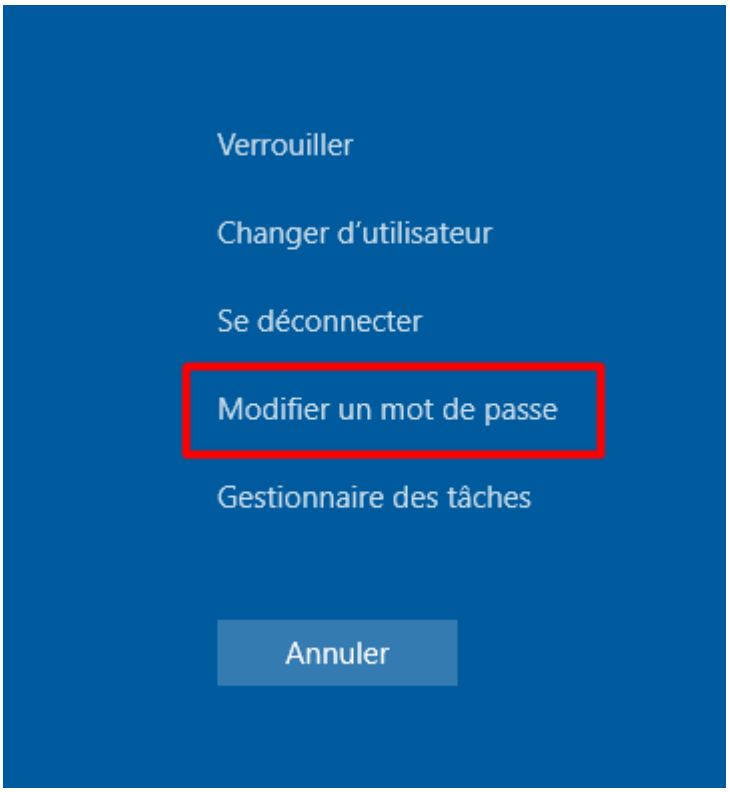


5- Une fois l'opération réussie, il suffit de cliquer sur « Terminer

Changement du code PIN PIV par défaut :

Après la signature du certificat, il faut désormais modifier le code PIN par défaut pour correspondre au code PIN enregistré dans la partie de l'enrôlement dédiée au FIDO.

1- Appuyez sur les touches « **CTRL + ALT + SUPPR** » afin d'ouvrir le menu de sécurité de Windows et cliquez sur « **Modifier un mot de passe** »

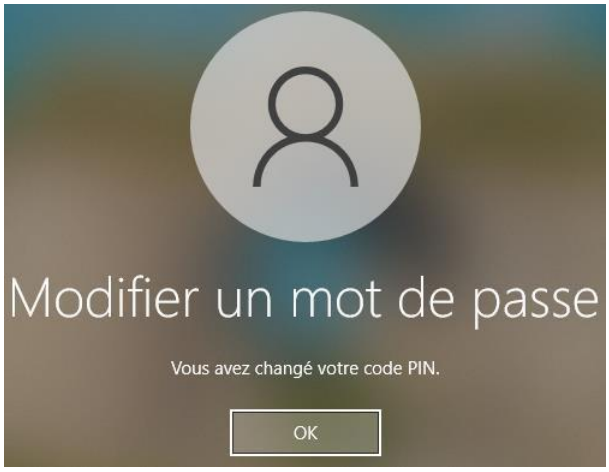


2- À cette étape il est important de vérifier que la méthode de connexion choisie pour modifier le mot de passe soit bien la bonne.
Pour se faire, vérifiez que ce soit bien « **Yubico YubiKey OTP+FIDO+CCID 0** » qui apparaisse à l'écran.
Si ce n'est pas le cas, il faudra cliquer sur « **Options de connexion** » et sélectionner la méthode de connexion par « **Carte à puce** » la plus à droite, puis cocher « **Modifier le code PIN** » afin de tomber sur le bon menu.

3- Une fois sur le bon menu, entrez le code PIN par défaut précédemment utilisé, soit « **123456** » dans le premier champ disponible

4- Renseignez votre nouveau code PIN à 6 caractères numériques et validez le changement.
Attention le code PIN renseigné doit être le même que celui enregistré à l'étape d'enrôlement du FIDO !

5- Une fois validé, Windows rappelle que le code PIN a bien été changé, il suffit d'appuyer sur « **OK** »



Etape 7 : Configuration de Windows Hello

Selon les modèles de PC, Windows Hello peut comprendre différentes fonctionnalités, à savoir (classées dans leur ordre de priorité) :

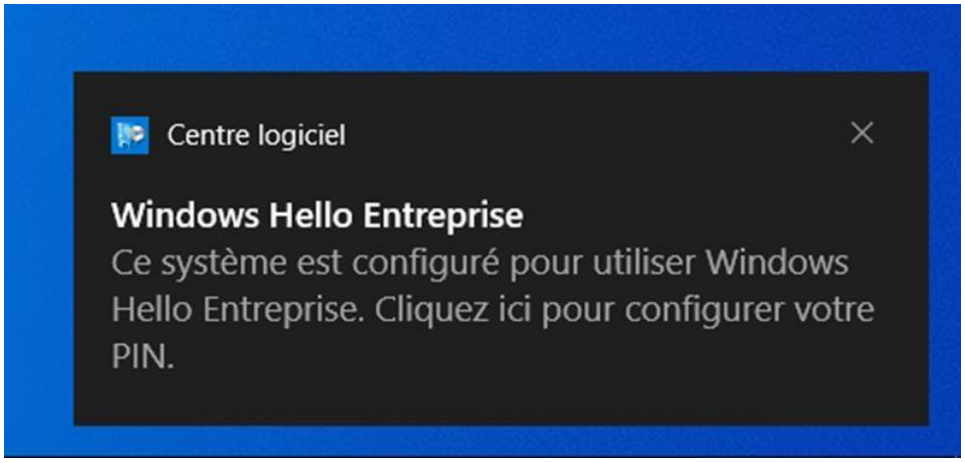
- La reconnaissance des visages
- La reconnaissance de l'empreinte digitale
- L'utilisation d'un code PIN dédié

Il est aussi à noter que les deux 1ères méthodes demanderont toujours la configuration d'un code PIN au cas où la reconnaissance de visage ou d'empreinte digitale ne fonctionne pas ou plus.

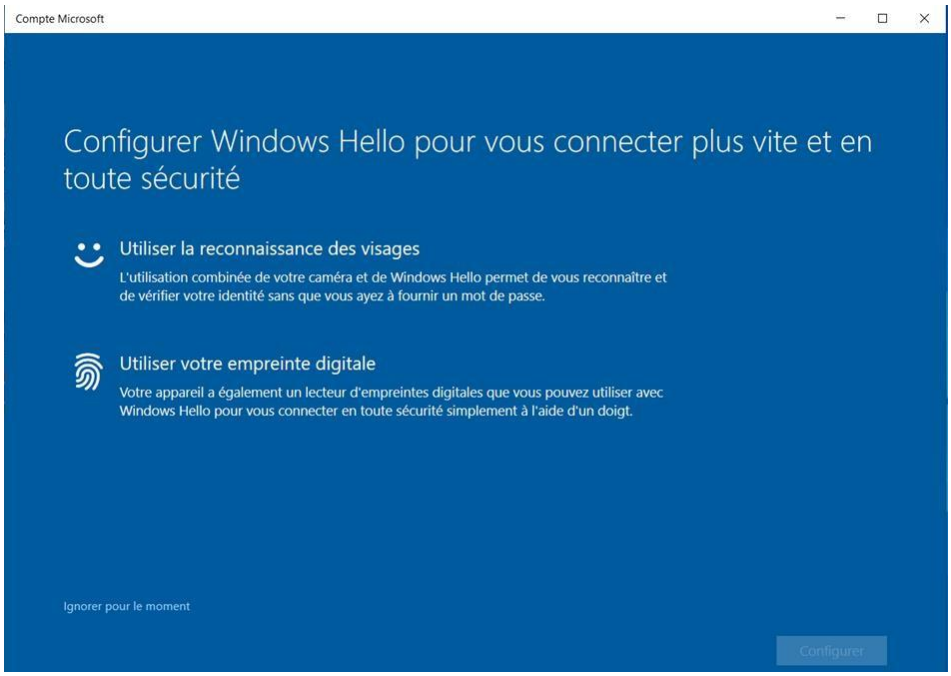
Il existe différents chemins afin de lancer la configuration de Windows

Hello. Méthode n°1 : Avec le pop-up du centre logiciel

1- Cliquez sur le pop-up afin de lancer la configuration de Windows Hello.

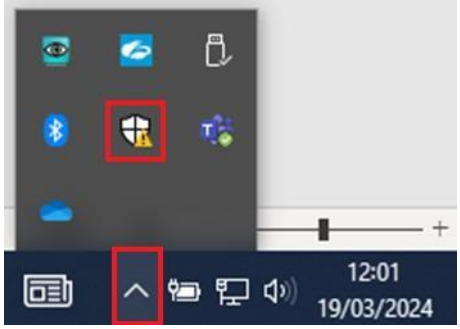


2- Vous arriverez sur la page de configuration de Windows Hello

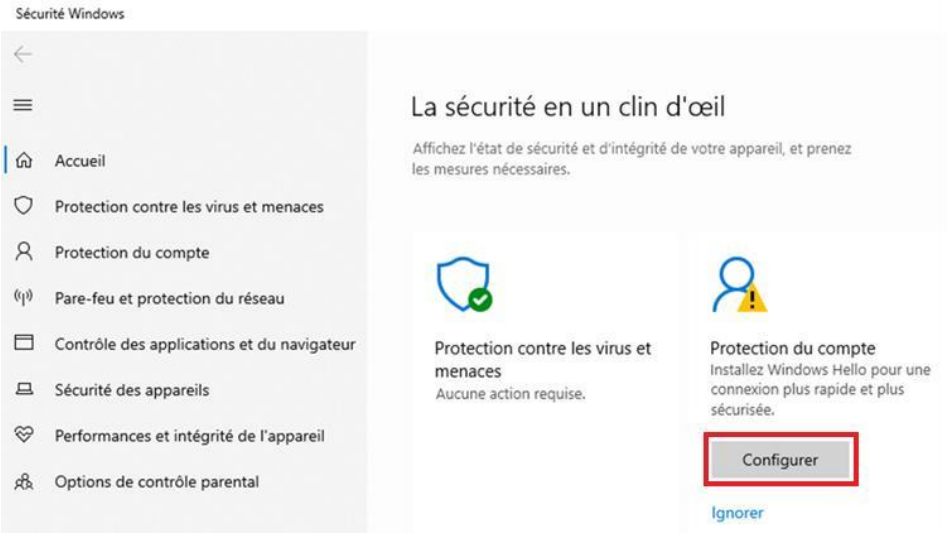


Méthode n°2 : En passant par l'icône Windows Defender de la barre de tâche

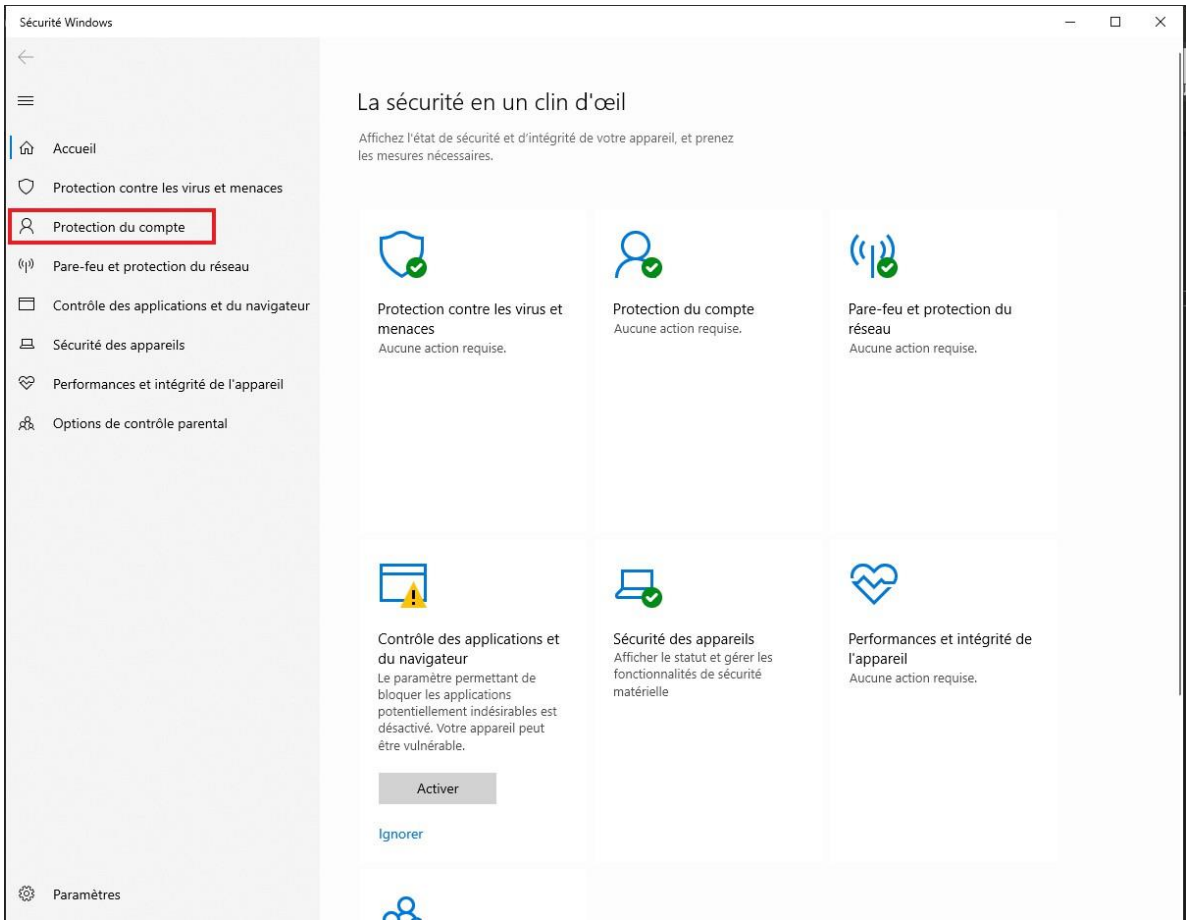
1- Cliquez sur le **chevron** situé à gauche de l'heure afin d'afficher les icônes cachées, puis
cliquez sur l'icône de **Windows Defender**



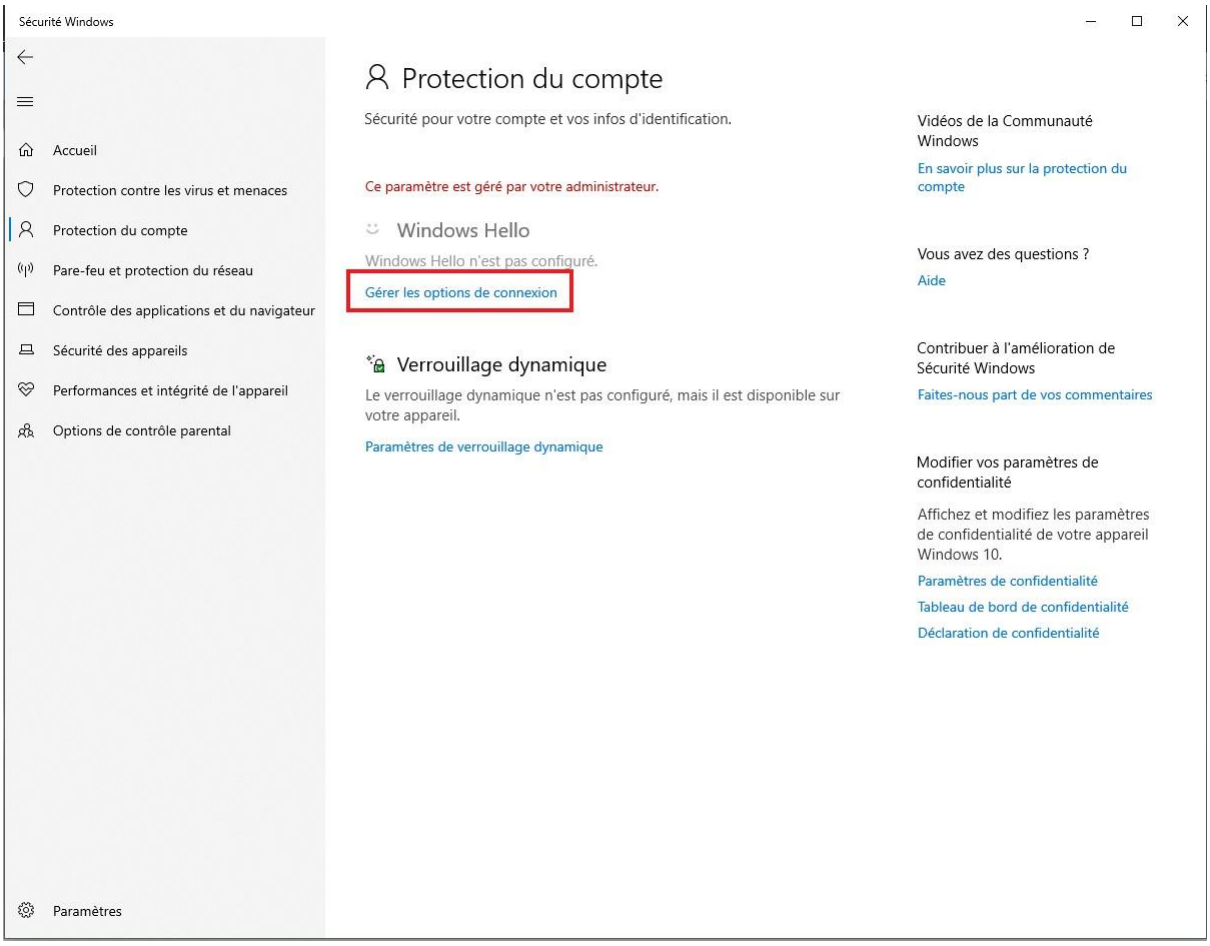
2- Une fois dans le menu de Sécurité Windows il faudra soit cliquer sur le bouton « **configurer** »
de la partie protection de compte de la page d'accueil.



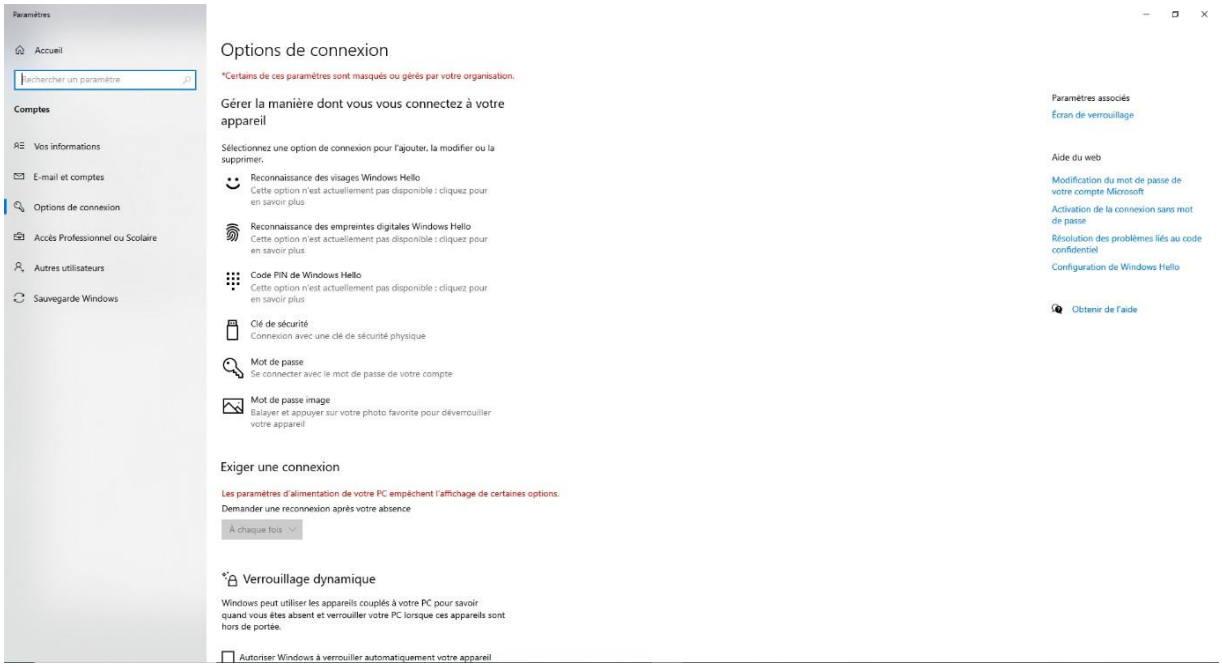
3- Ou alors cliquez sur « **Protection de compte** »



4- Puis « **Options de connexion** »

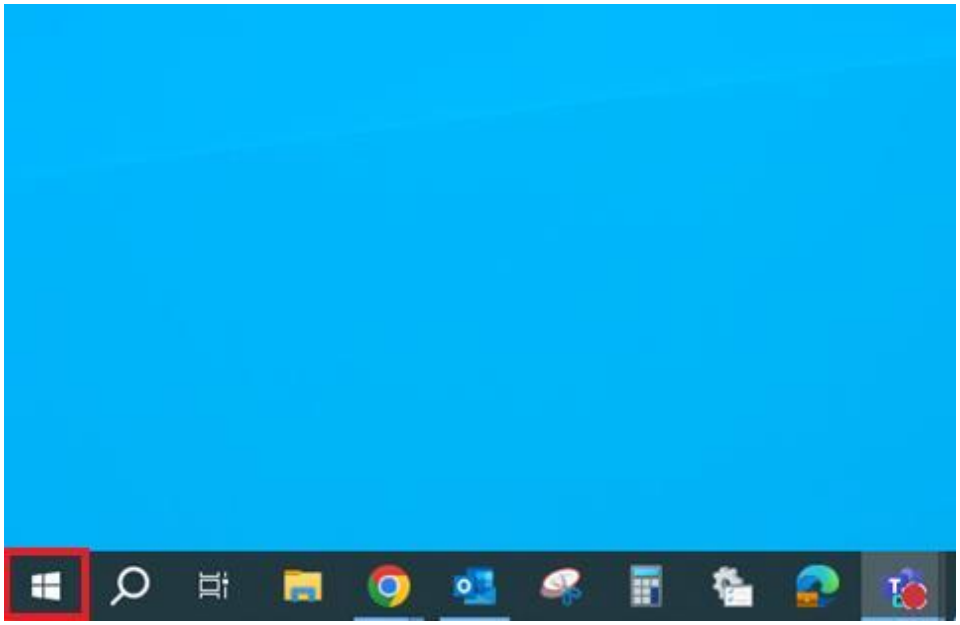


5- Afin d'arriver sur la page de configuration des méthodes de connexion à l'appareil.

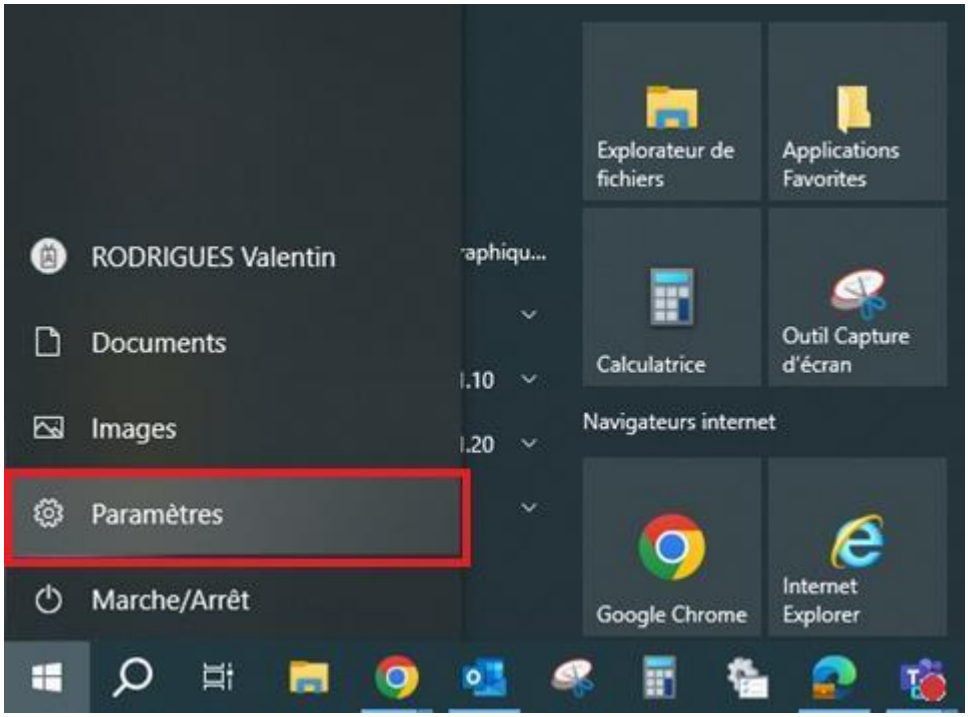


Méthode n°3 : En passant utilisant les paramètres de Windows

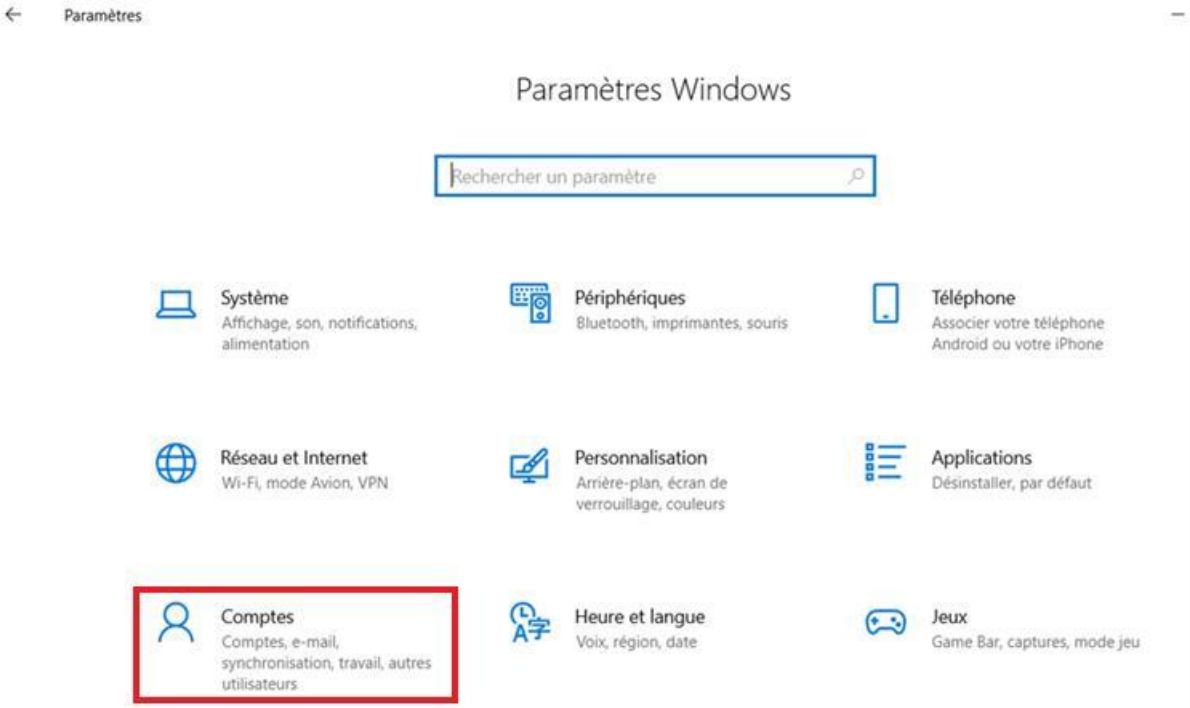
1- Cliquez sur le bouton « **Démarrer** »



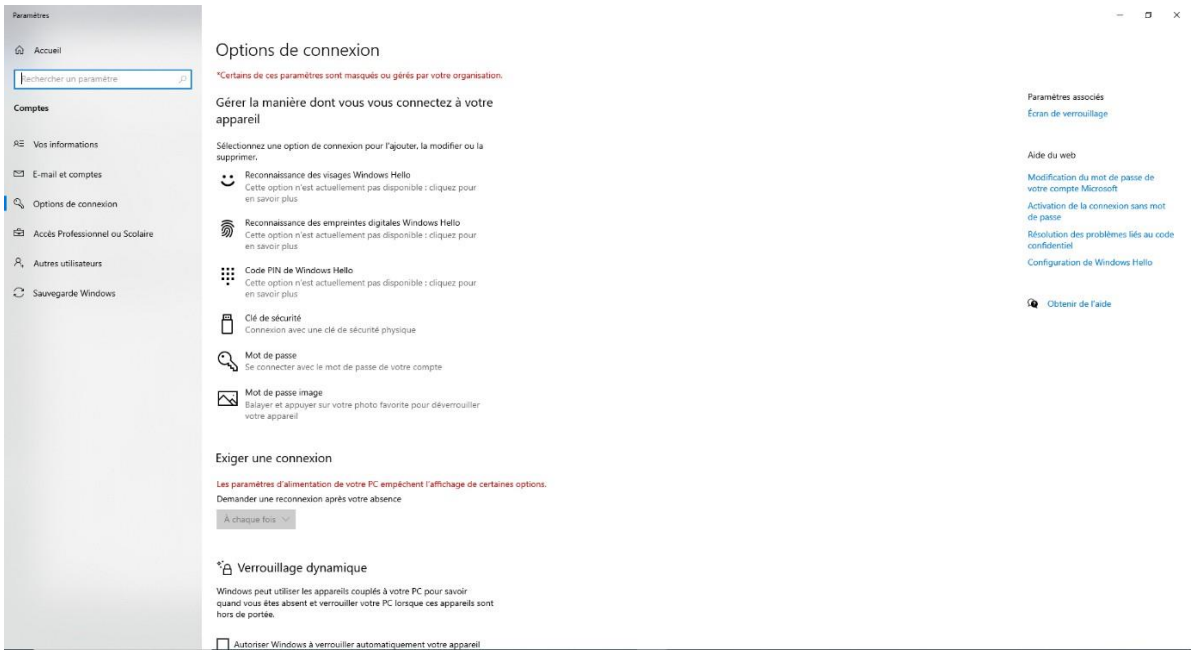
2- Cliquez sur « **Paramètres** »



3- Une fois dans le menu des paramètres de Windows, cliquez sur « **Comptes** »



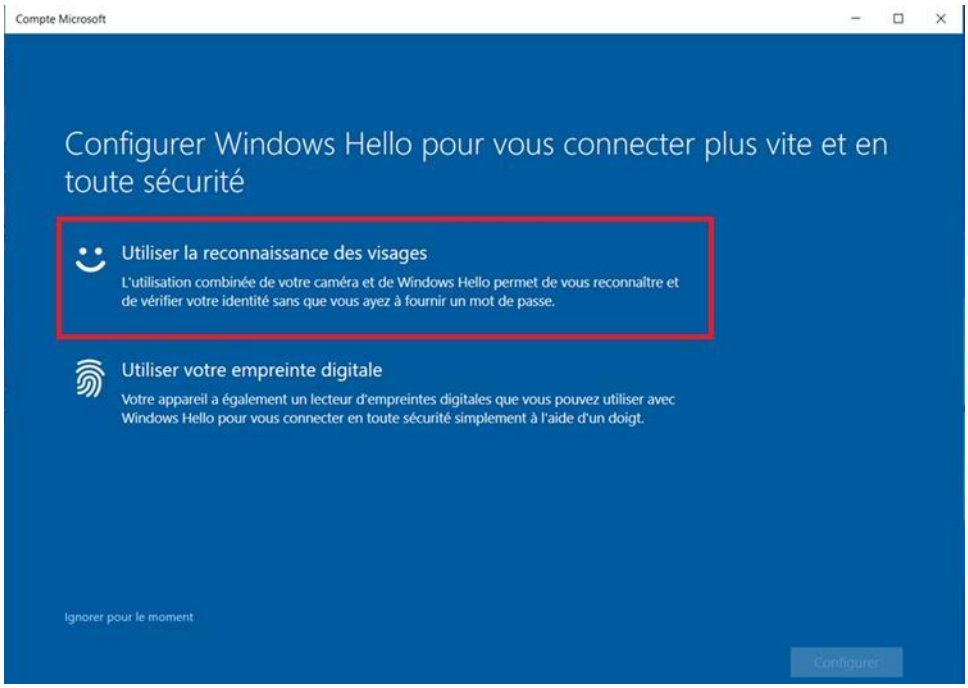
4- Cliquez sur « **Option de connexion** » afin d'arriver sur la page de configuration des méthodes de connexion à l'appareil.



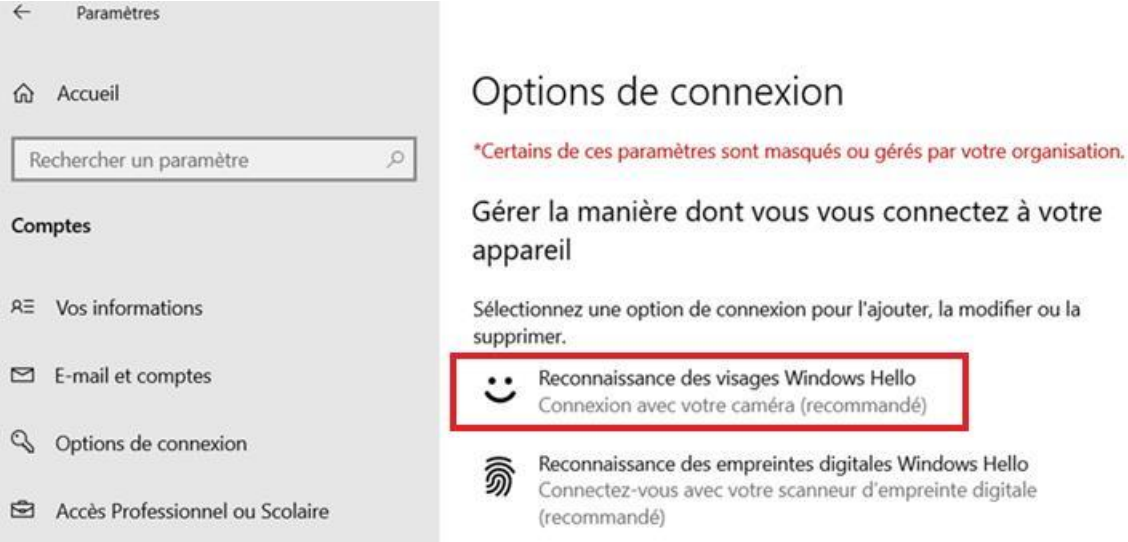
Suite de la configuration de Windows Hello :

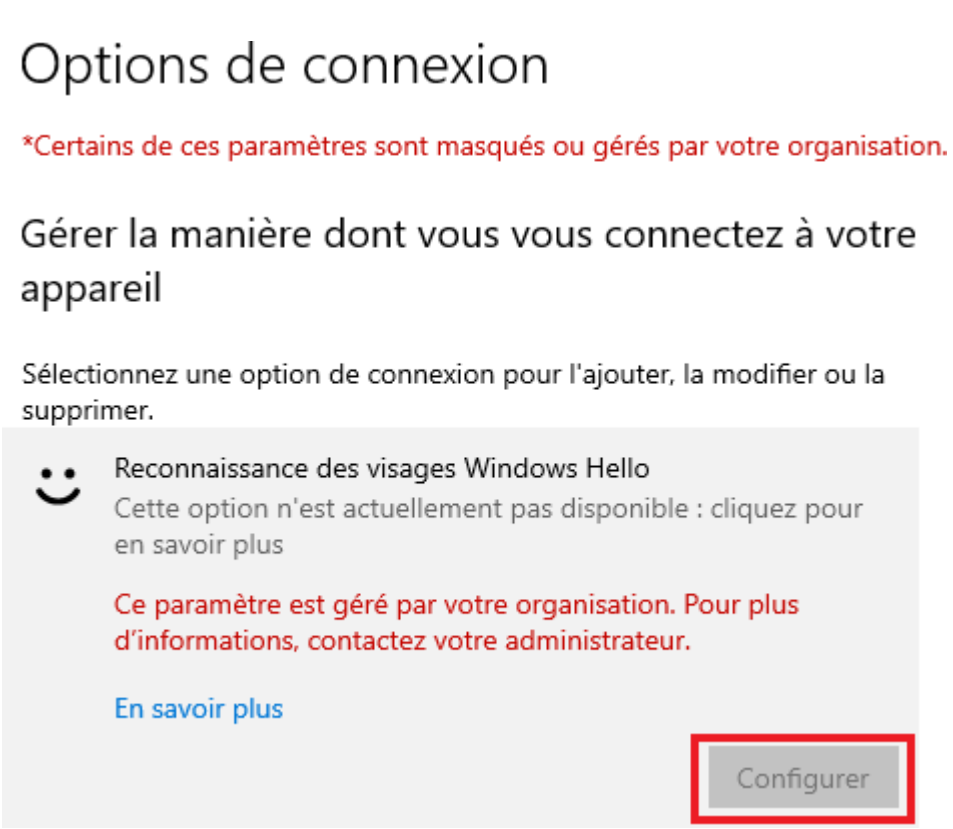
a) **Configuration de la reconnaissance faciale** :

1- Sélectionnez « **Utiliser la reconnaissance des visages** »

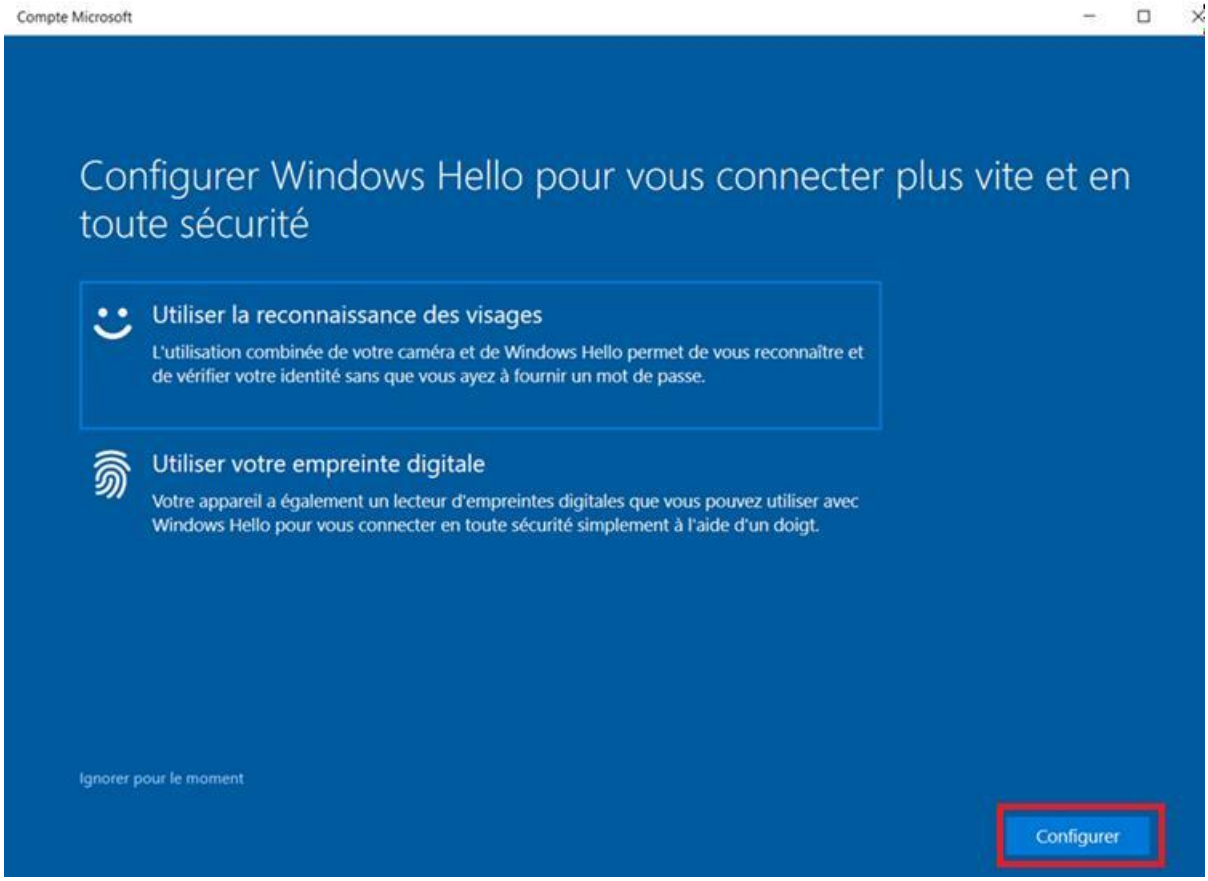


Si ce n'est pas la méthode par pop-up qui a été employée pour effectuer la configuration, il faudra sélectionner « **Reconnaissance des visages Windows Hello** » et appuyer sur « **Configurer** » dans le menu des « **Options de connexion** » afin de lancer la configuration.


Paramètres
Accueil
Rechercher un paramètre
Comptes
Vos informations
E-mail et comptes
Options de connexion
Accès Professionnel ou Scolaire
Options de connexion
*Certains de ces paramètres sont masqués ou gérés par votre organisation.
Gérer la manière dont vous vous connectez à votre appareil
Sélectionnez une option de connexion pour l'ajouter, la modifier ou la supprimer.
Reconnaissance des visages Windows Hello
Connexion avec votre caméra (recommandé)
Reconnaissance des empreintes digitales Windows Hello
Connectez-vous avec votre scanneur d'empreinte digitale (recommandé)


Options de connexion
*Certains de ces paramètres sont masqués ou gérés par votre organisation.
Gérer la manière dont vous vous connectez à votre appareil
Sélectionnez une option de connexion pour l'ajouter, la modifier ou la supprimer.
Reconnaissance des visages Windows Hello
Cette option n'est actuellement pas disponible : cliquez pour en savoir plus
Ce paramètre est géré par votre organisation. Pour plus d'informations, contactez votre administrateur.
En savoir plus
Configurer

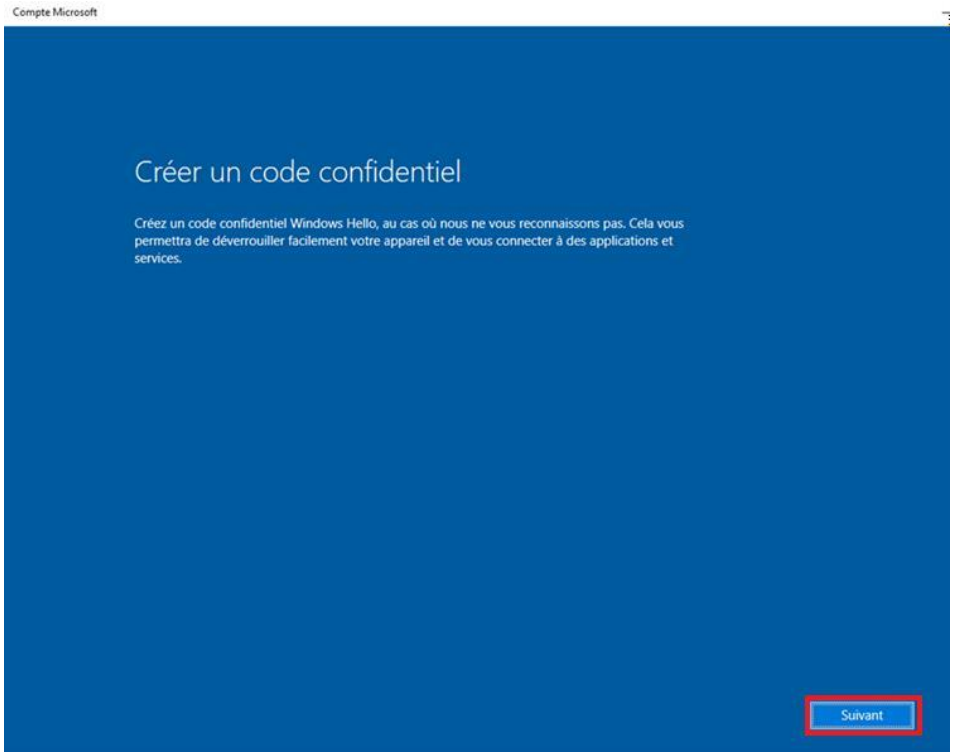
2- Cliquez sur « **Configurer** »



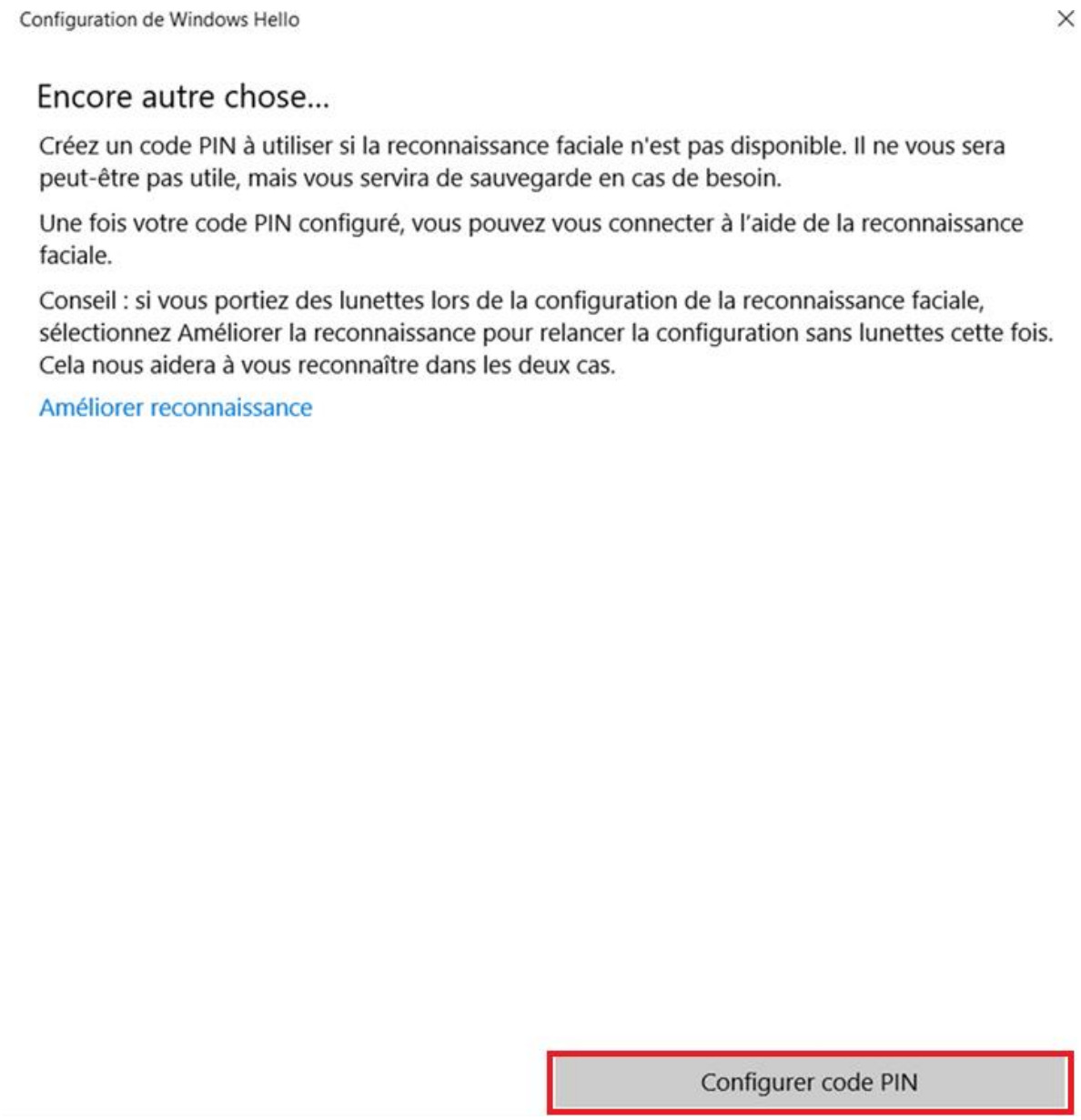
3- Cela va lancer une fenêtre afin d'effectuer l'enregistrement du visage. Si l'obturateur de la
caméra est fermé vous obtiendrez ceci :

4- Une fois l'obturateur ouvert, il faudra suivre les instructions indiquées à l'écran. Il sera important de laisser le carré bleu faire le tour pendant l'analyse.

5- Une fois la reconnaissance faciale terminée, il vous sera demandé de créer un code confidentiel sous forme de code PIN, il faudra alors cliquer sur « **Suivant** »



SI vous n’avez pas utilisé la méthode avec le pop-up voici ce qui devrai apparaitre



Compte Microsoft

Utiliser Windows Hello avec votre compte

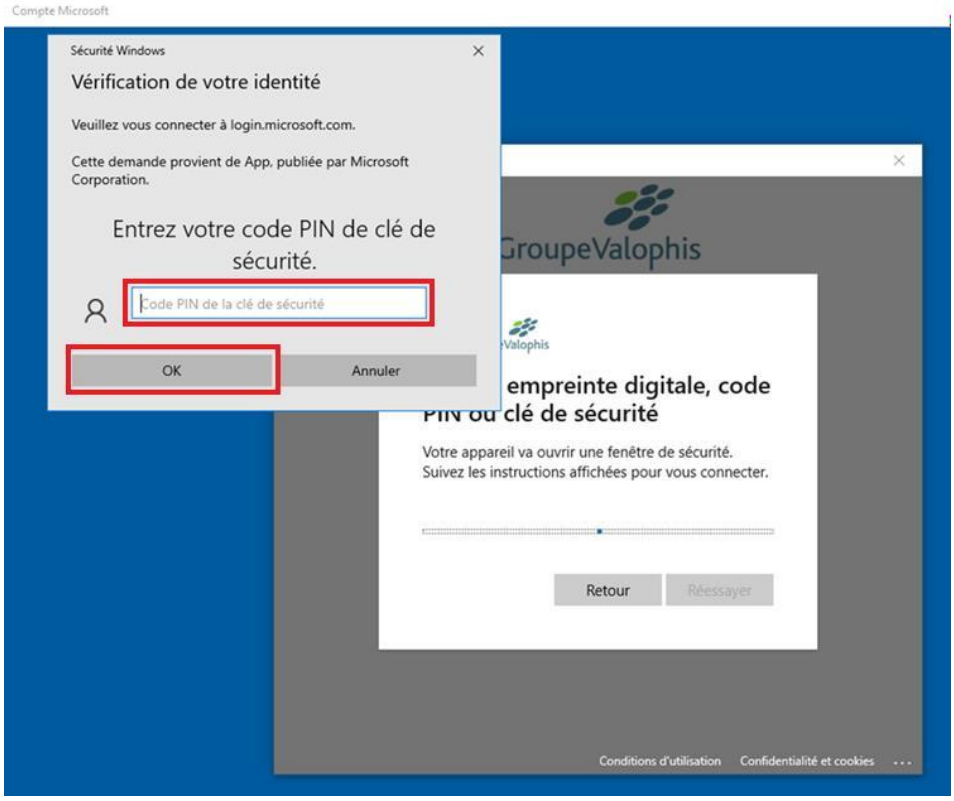
Votre organisation requiert la configuration de votre compte professionnel ou scolaire avec la reconnaissance des visages Windows Hello, Fingerprint ou PIN.

Si vous avez déjà configuré Windows Hello sur cet appareil, nous l'ajouterons automatiquement à ce compte. Vous serez peut-être invité à revérifier avec Windows Hello.

Si votre organisation requiert un code PIN plus complexe, Windows vous invitera à le changer.

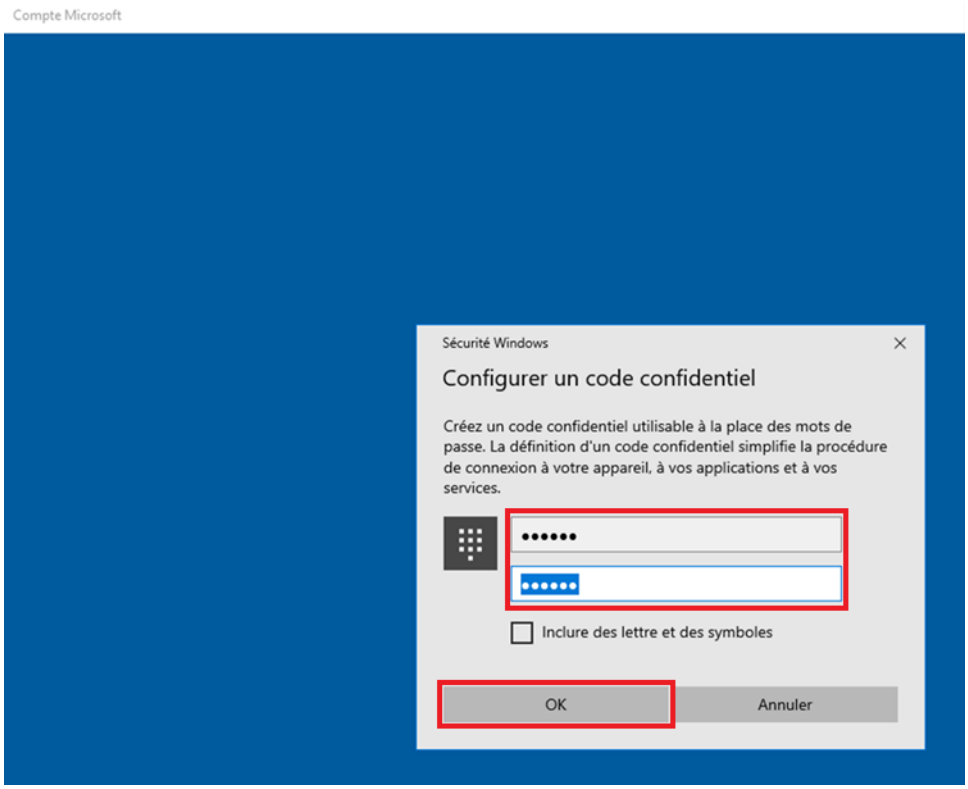
OK

6- Il vous sera alors demandé de vous authentifier, vous utiliserez la clé Yubikey et le code PIN précédemment configuré afin de vous authentifier. Une fois le code PIN renseigné il faudra appuyer sur « **OK** ».



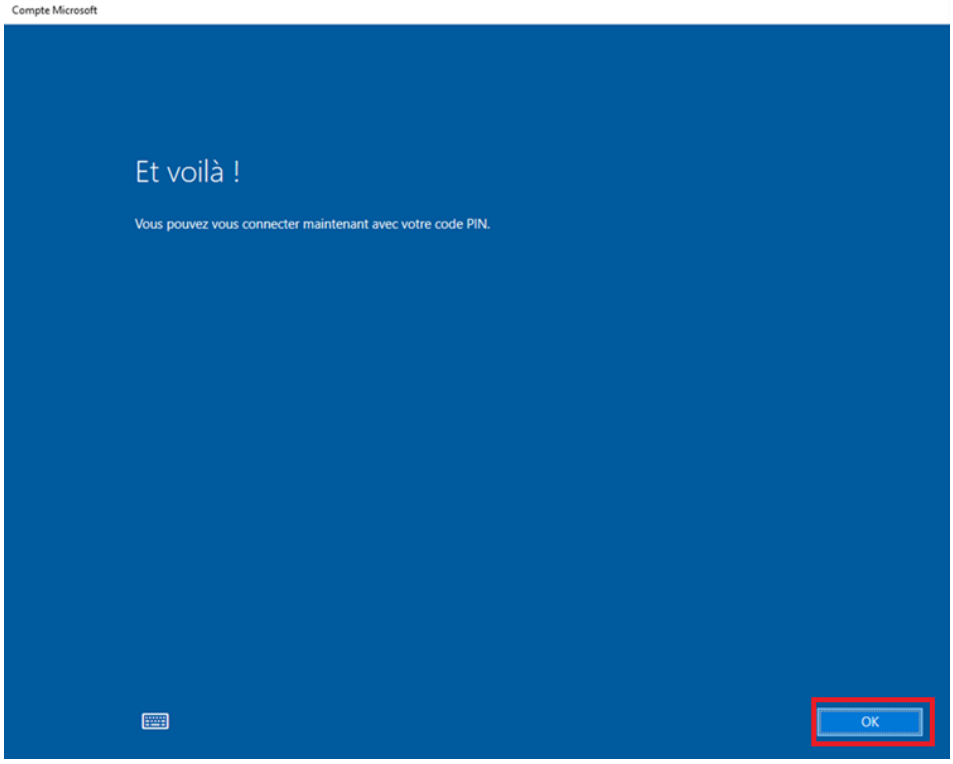
7- Vous devrez alors configurer le code PIN confidentiel pour Windows Hello. Cette fois, le code PIN devra être différent des précédents et **devra faire 16 caractères minimum**.

Une fois le code Pin renseigné il faudra appuyer sur « **OK** »

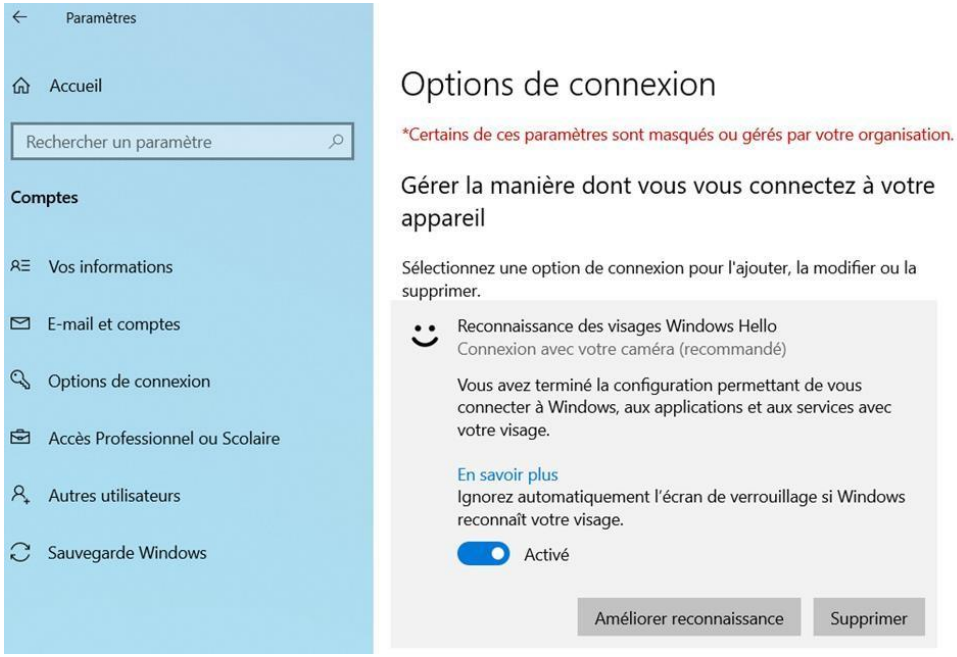


En effet ce code PIN est une **méthode de secours**, et pas une méthode principale d'authentification d'où la différence de complexité entre celui-ci et les autres

8- La configuration de la reconnaissance de visage pour Windows Hello est désormais terminée, il suffit d'appuyer sur « **OK** »

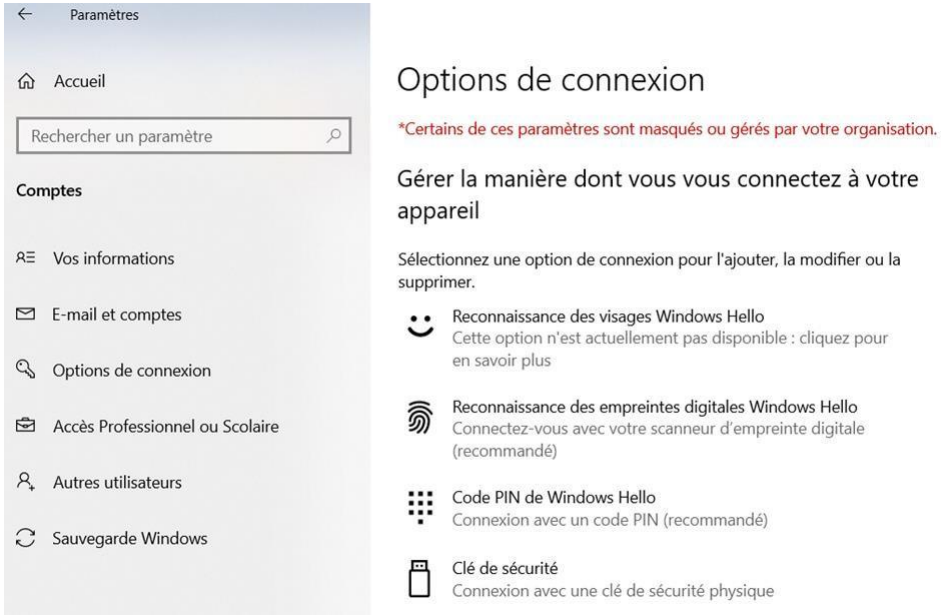


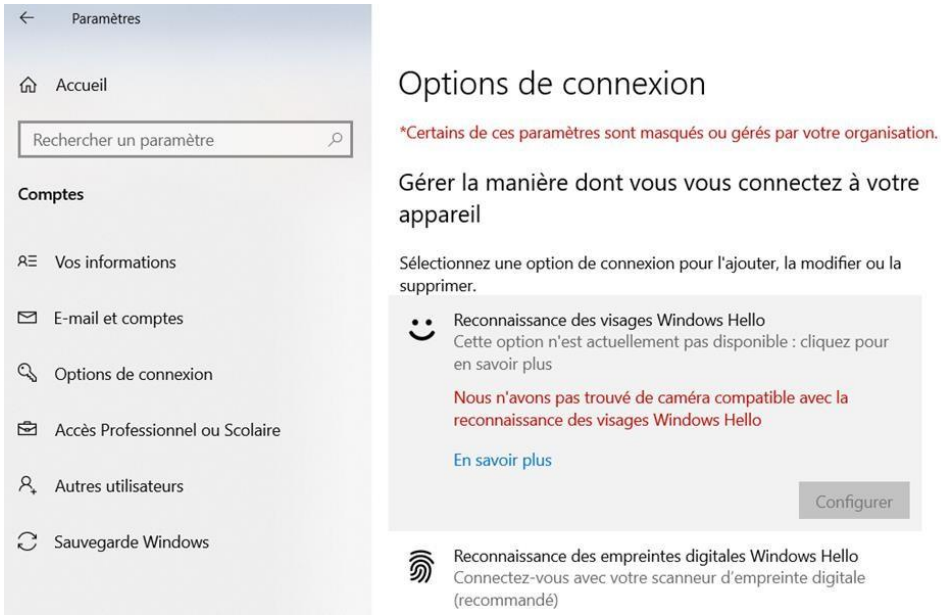
9- La reconnaissance des visages apparaîtra désormais comme configurée dans les options de connexion



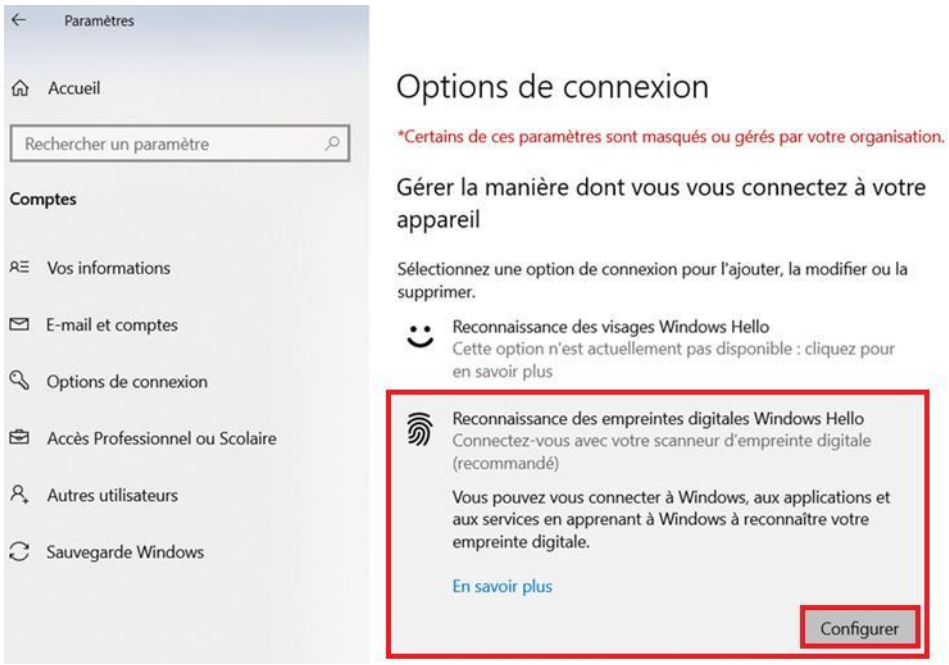
b) Configuration de la reconnaissance des empreintes digitales :

Si la reconnaissance faciale n'est pas disponible sur le poste, il faudra alors configurer le Windows Hello pour la reconnaissance d'empreinte digitale.

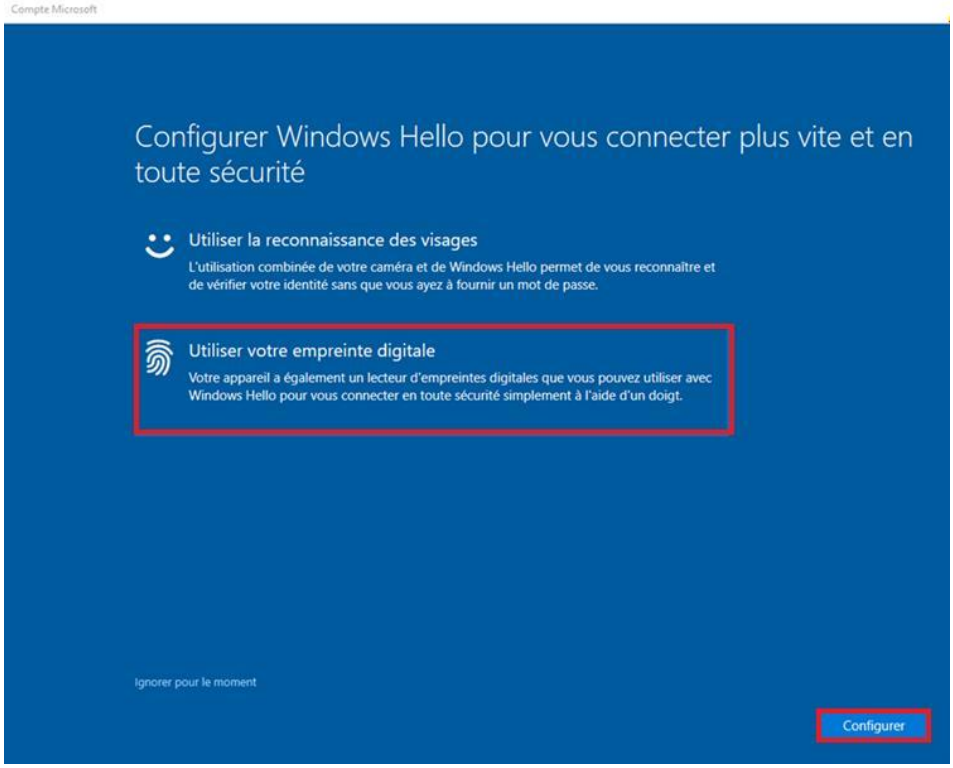




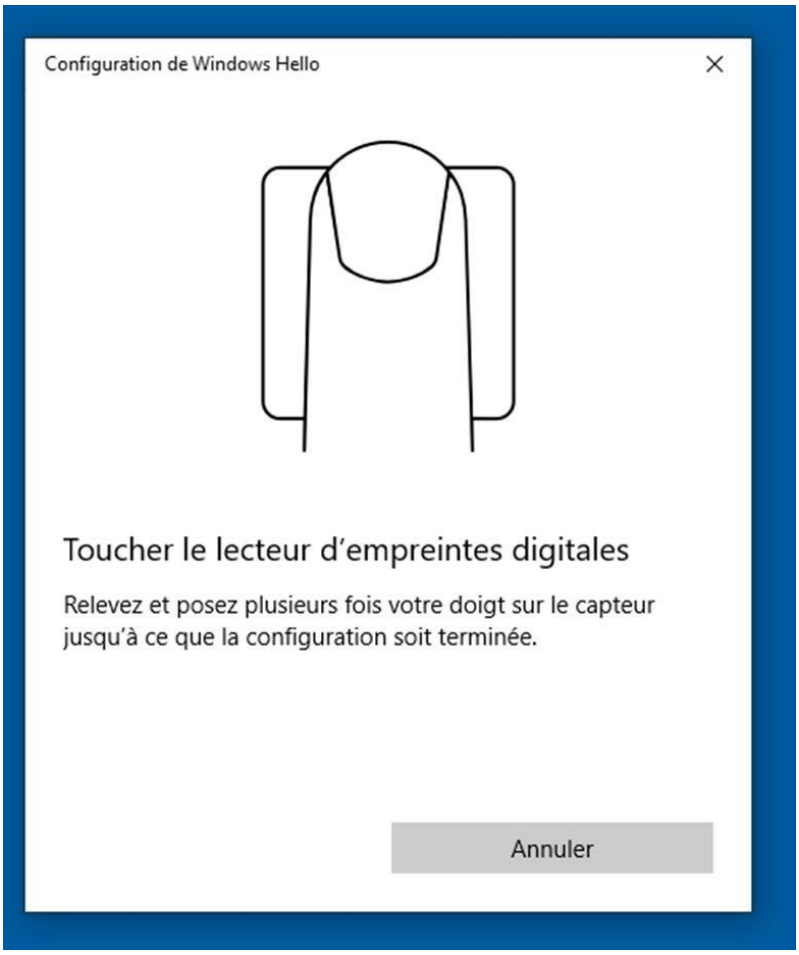
1- Sélectionnez « **Reconnaissance des empreintes digitales Windows Hello** », puis cliquez sur
« **Configurer** ».



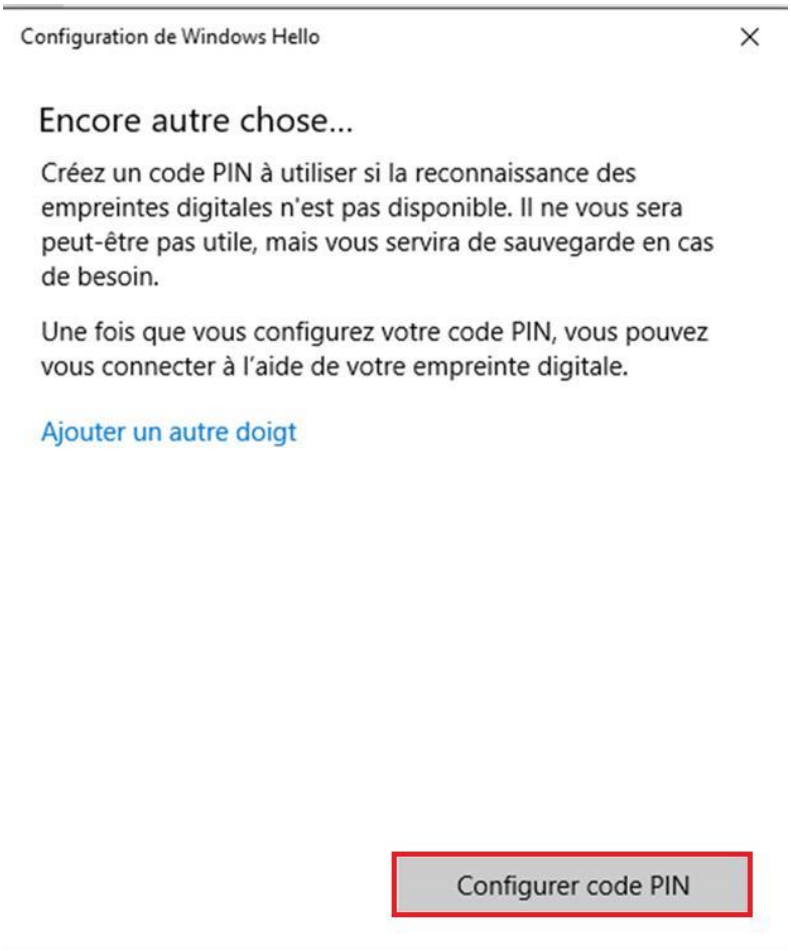
Ou bien


Compte Microsoft
Configurer Windows Hello pour vous connecter plus vite et en toute sécurité
Utiliser la reconnaissance des visages
L'utilisation combinée de votre caméra et de Windows Hello permet de vous reconnaître et de vérifier votre identité sans que vous ayez à fournir un mot de passe.
Utiliser votre empreinte digitale
Votre appareil a également un lecteur d'empreintes digitales que vous pouvez utiliser avec Windows Hello pour vous connecter en toute sécurité simplement à l'aide d'un doigt.
Ignorer pour le moment
Configurer

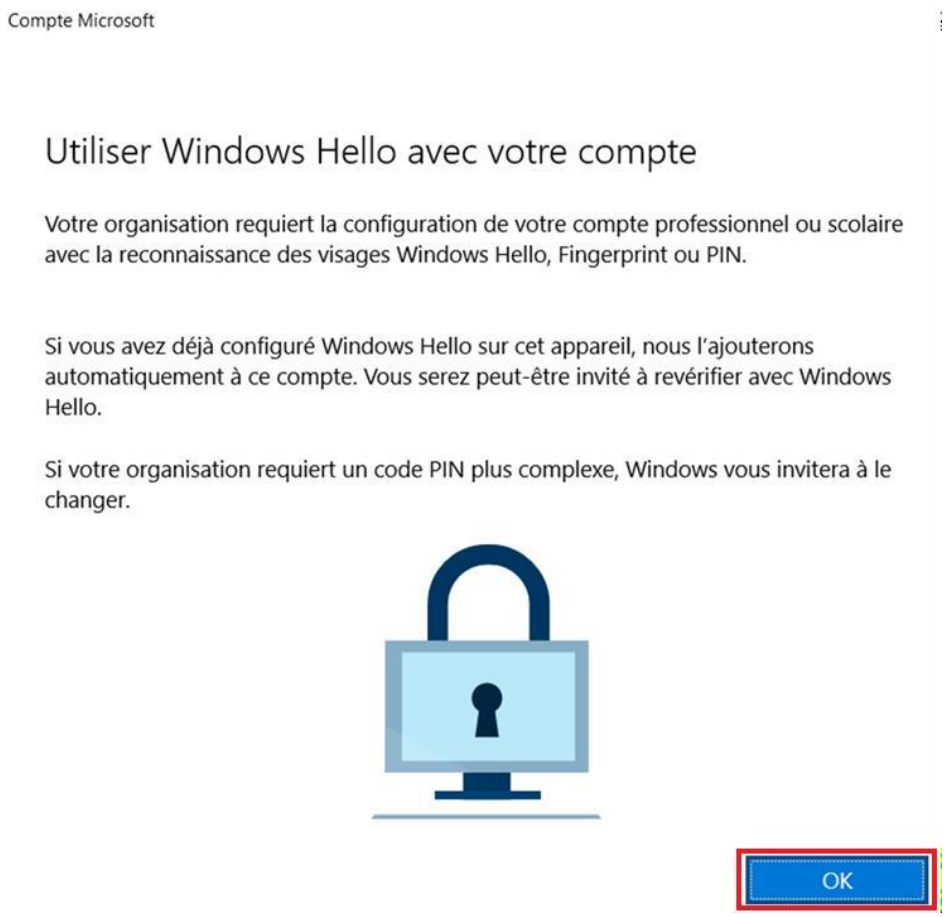
2- Une fois la reconnaissance des empreintes digitales lancée, il faudra suivre attentivement les instructions à l'écran



3- Une fois la reconnaissance des empreintes effectuée, il vous sera demandé de créer un code confidentiel sous forme de code PIN, il faudra alors cliquer sur « **Configurer le code PIN** »

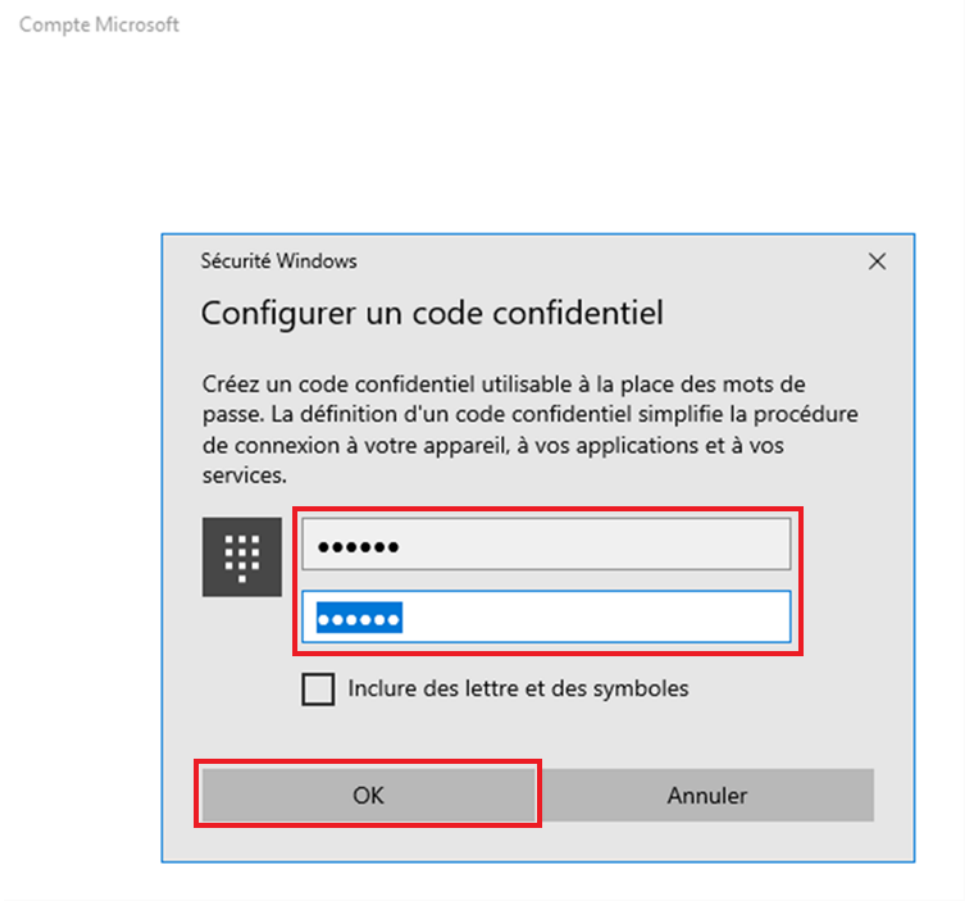


4- Il faudra cliquer sur « **OK** »



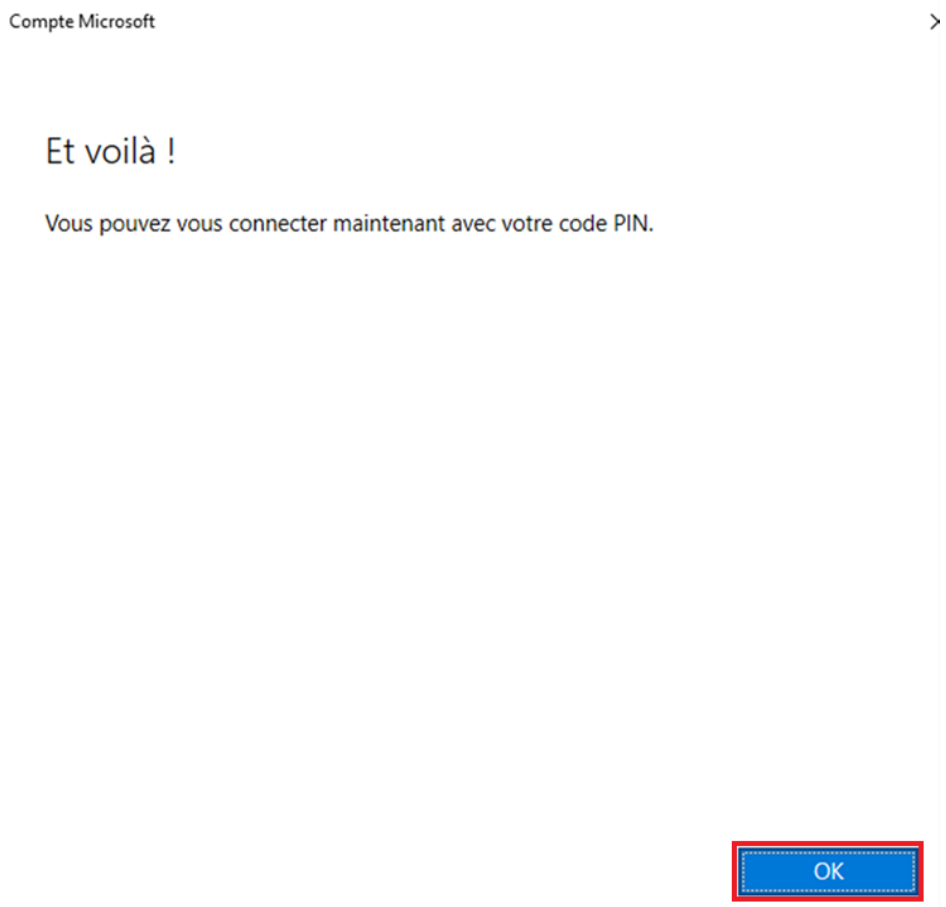
5- Vous devrez alors configurer le code PIN confidentiel pour Windows Hello. Cette fois, le code PIN devra être différent des précédents et **devra faire 16 caractères minimum** (à déterminer).

Une fois le code Pin renseigné il faudra appuyer sur « **OK** »

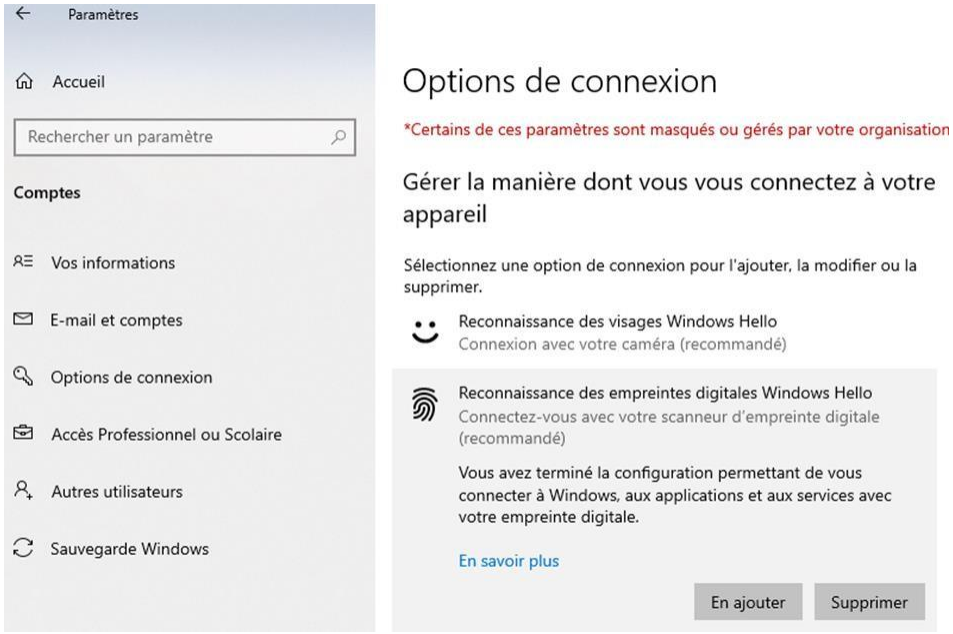


En effet ce code PIN est une **méthode de secours**, et pas une méthode principale d'authentification d'où la différence de complexité entre celui-ci et les autres

6- La configuration de la reconnaissance des empreintes pour Windows Hello est désormais
terminée, il suffit d'appuyer sur « **OK** »



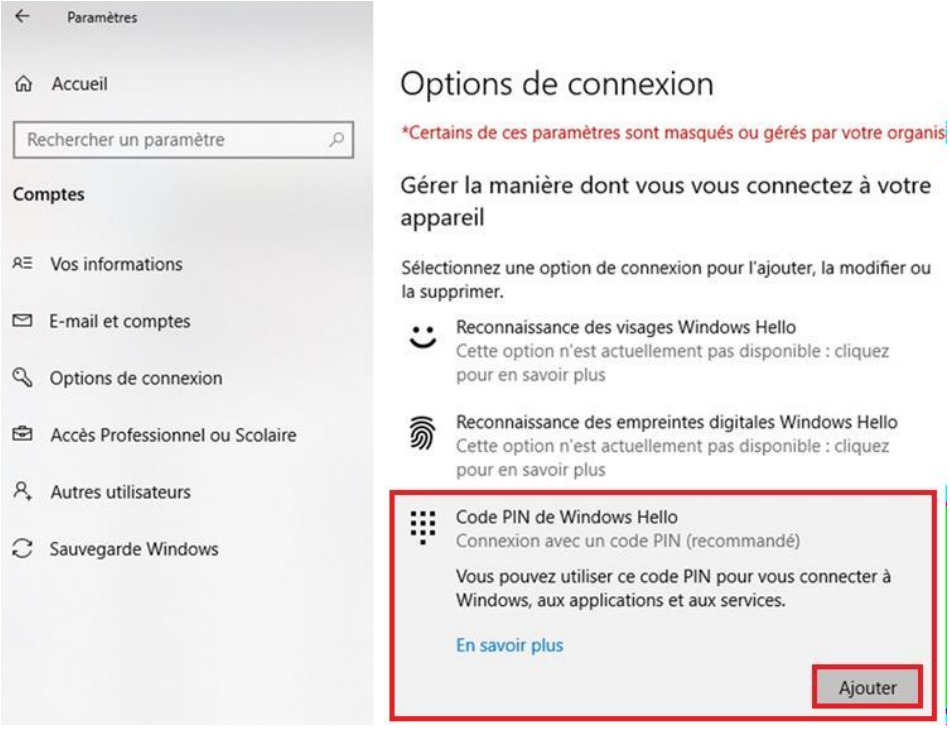
7- La reconnaissance des visages apparaîtra désormais comme configurée dans les options de connexion



c) Configuration du code PIN Windows Hello :

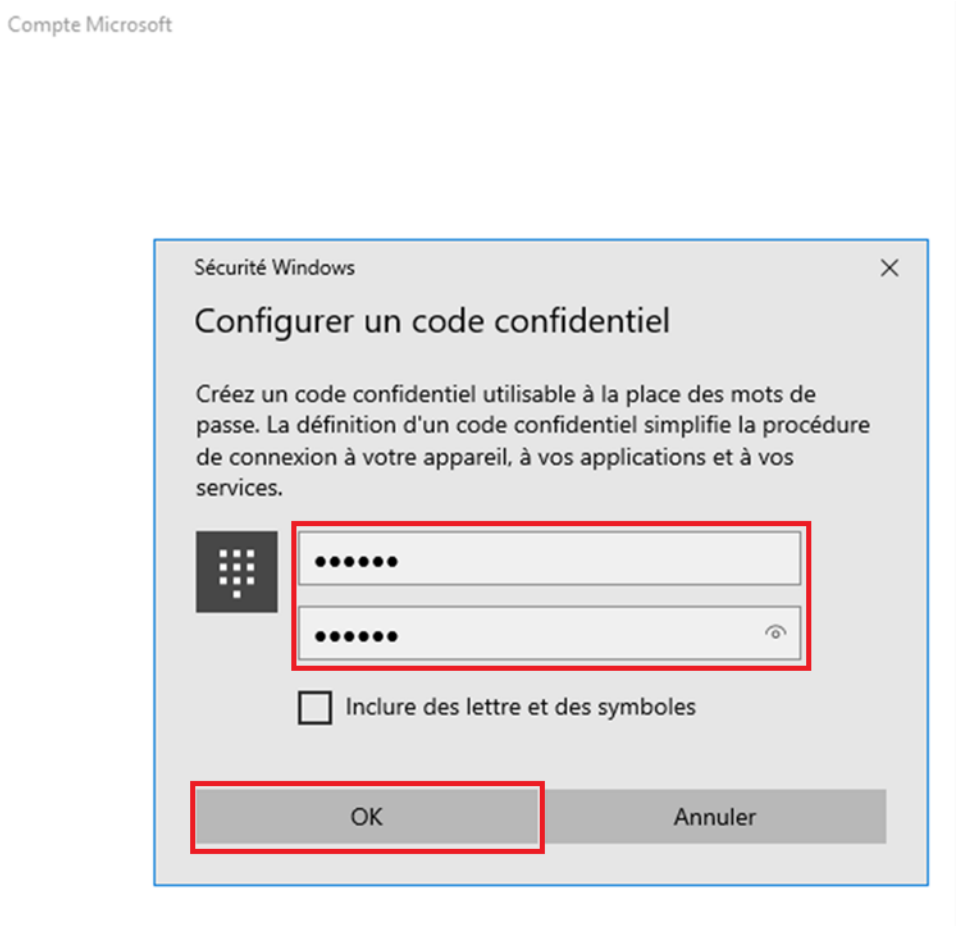
Si la reconnaissance du visage ou des empreintes ne sont pas disponibles, il faudra alors effectuer la configuration du code PIN Windows Hello

1- Sélectionnez « **Code PIN de Windows Hello** », puis cliquez sur « **Ajouter** »



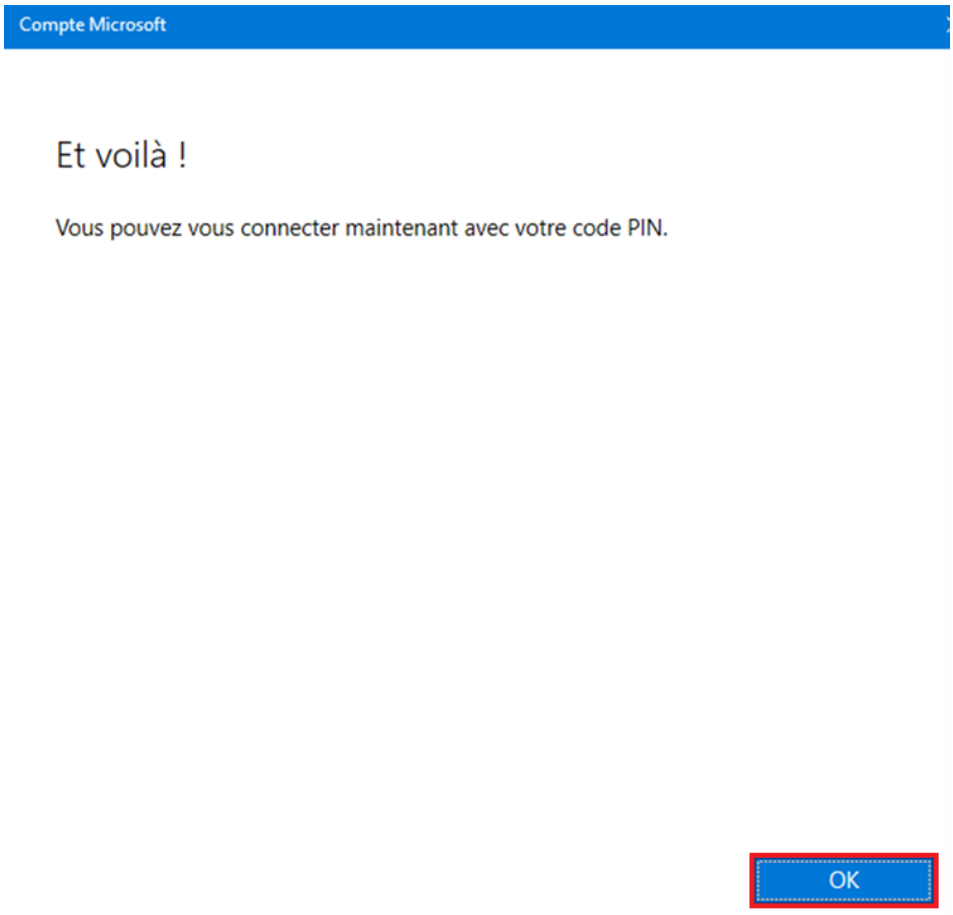
2- Vous devrez alors configurer le code PIN confidentiel pour Windows Hello. Cette fois, le code PIN devra être différent des précédents et **devra faire 16 caractères minimum** (à déterminer).

Une fois le code Pin renseigné il faudra appuyer sur « **OK** »

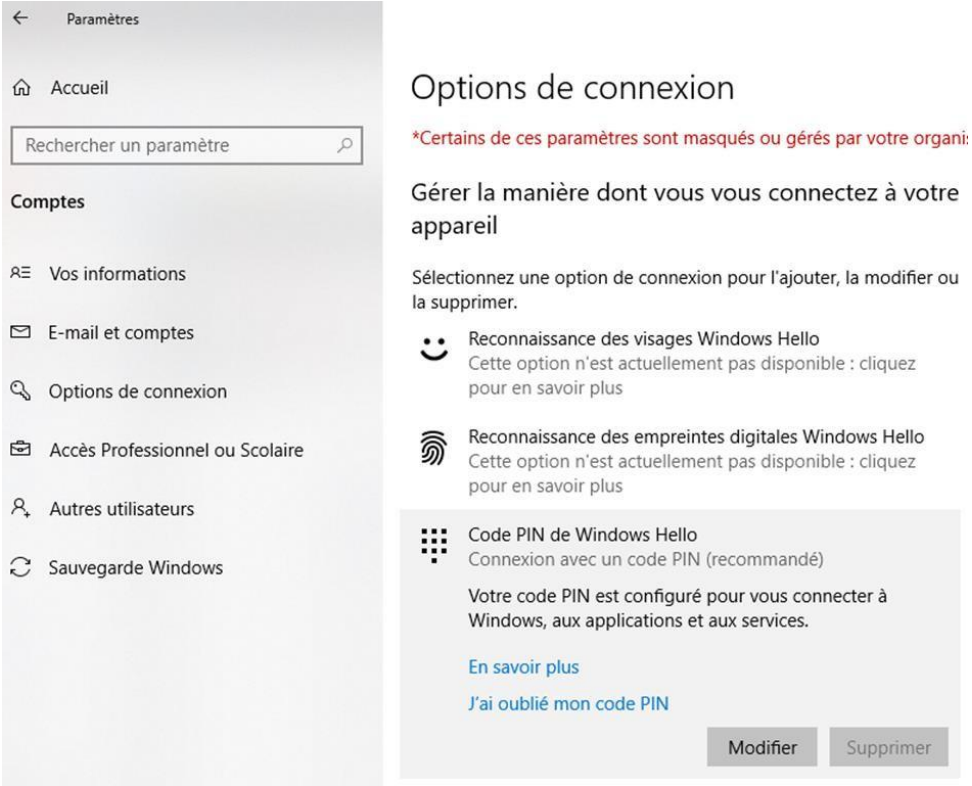


En effet ce code PIN est une **méthode de secours**, et pas une méthode principale d'authentification d'où la différence de complexité entre celui-ci et les autres

3- La configuration du code PIN pour Windows Hello est désormais terminée, il suffit d'appuyer
sur « **OK** »



4- Le code PIN apparaîtra désormais comme configuré dans les options de connexion



Les différentes méthodes d'authentification passwordless sont désormais configurées.

La toute dernière étape est de se reconnecter à son poste de travail en **utilisant la clé** comme méthode d'authentification.